

Private Federated Aggregation of LLM-Agent Memory

Usable Shared Memory with a Measurable Leakage-Drop Guarantee under Secure Aggregation and the Skellam Mechanism

Abstract

LLM agents increasingly accumulate **per-user memory**, distilled notes, preferences, and skill embeddings (as in A-MEM and Mem0), that make them personal and effective. Pooling these memories *across users* would give a fleet of agents a shared **routing prior** over what the fleet collectively knows, but the memory objects are exactly the sensitive artifact: recent extraction (MEXTRA) and membership-inference (MRMMIA) attacks recover verbatim user facts from agent memory. We ask whether a shared memory pool can be made **useful and provably private at once**.

We aggregate per-user memory-note embeddings into a shared, bucketed **centroid memory** under **Secure Aggregation (SecAgg)** composed with the **discrete Skellam mechanism**, so the pooled memory carries a single central differential-privacy guarantee with **no trusted curator** and **no individual note in the clear**. The payload is new but the cryptographic path is verbatim prior work, which lets us reuse a rigorous discrete-DP accountant. We evaluate on **LongMemEval** (real long-horizon conversational memory) and on **LLM-distilled A-MEM/Mem0-style notes** — and we insist throughout that utility and leakage be read **at the same operating point**, a discipline that turns out to be load-bearing.

Four findings.

(1) A joint frontier, usable and safe at one operating point. We measure both axes at every fidelity K — which a two-axis claim requires, and which our own superseded draft did not do (it reported utility only at $K \leq 256$ and leakage only at $K \geq 512$, so its two headline numbers described disjoint releases). On the frontier the coarse- K regime is usable **and** safe together: at $K=32$ the pool retains **95% of clean evidence-recall at $\epsilon \approx 9.3$** ($0.428 \rightarrow 0.406$, against 0.156 chance) while a calibrated offline-LiRA attack falls from **AUC 0.833 / TPR@1%FPR 0.175 (17× the floor) to the 1% false-positive floor (0.011)**, and reconstruction-decode from 0.771 to 0.396. At $K=128$ (72% retention) *both* attacks reach their floor. The privacy axis is **flat in K** — DP defeats the calibrated attack at every fidelity — so K is chosen on utility alone (§7.1).

(2) The weak attack everyone reaches for is blind exactly where you would deploy. The uncalibrated cosine proxy used by prior agent-memory work reads **0.504 — chance — at $K=32$** , on the very clean release the calibrated attack breaks at AUC 0.833 with 77% note reconstruction. A proxy-only evaluation would therefore have certified a leaking pool as safe, and would have concluded (as our superseded draft did) that leakage is a sparse-regime curiosity rather than a property of the pool one would actually

ship. The endpoint is real; the proxy could not see it (§7.5). The **published MEXTRA/MRMMIA attacks against a live agent** succeed on a raw-text memory (recovery 1.0, AUC 0.98) yet recover **nothing** against our centroid release (§7.10).

(3) Data-dependent preprocessing silently inflates DP-utility results. Two steps every such pipeline takes for granted — fitting a PCA on the users' own notes, and reading the clipping bound off the empirical norms — are themselves unaccounted releases. The first also *manufactures* the "tiny- d is Pareto-optimal" crossover that a previous draft of this paper, and the wider literature, read as a property of dimension. Replacing it with a public-seed random projection (data-independent, **zero** ϵ) removes the crossover entirely: tiny- d becomes the *worst* choice, and pre-DP leakage is saturated across d , with an identity-projection control that all three projections must and do agree on (§7.4). Selecting the clip bound with the exponential mechanism instead costs **0.2% of the budget** (§5.2). The DP conclusions are unaffected — they strengthen.

(4) A memory is re-aggregated, not released once, so the budget must compose. Naive repeated release destroys the guarantee: a month of daily re-aggregation at the single-shot σ costs **$\epsilon \approx 93$, not 9.3**. But the required noise grows only as $\sqrt{T}$, so a cadence can be *bought* up front — a **monthly re-aggregation sustained for a full year fits inside the same $\epsilon \approx 9.3$ at 81% retention** (§5.7). We further show the discrete mechanism is **privacy-free at our quantiser resolution** and that a **vector-only release dominates** the natural two-channel design (identical utility, $\sim 1.5\times$ tighter ϵ). Counter-intuitively, **LLM-distilled notes leak more than raw turns** (distillation concentrates identifying facts), yet DP collapses both to chance, so the realistic payload *strengthens* the case.

1. Introduction

Agent memory is the new sensitive payload. Production LLM-agent frameworks (A-MEM, Mem0) persist a per-user store of distilled notes: "the user is allergic to penicillin," "prefers metric units," "is migrating a Postgres 14 cluster." This memory is what makes an agent personal, and it is also a dense concentrate of personally identifying information. A natural, high-value idea is to **share memory across users**, so that a fleet of agents can profit from what the fleet collectively knows. But naively pooling raw notes is a privacy disaster, and recent work shows the threat is concrete, not hypothetical: **MEXTRA** [11] extracts verbatim memory content and **MRMMIA** [12] performs membership inference against agent memory with high success.

What a private pool can and cannot be: a routing prior, not a note exchange. We are precise about the object we release, because it bounds what may honestly be claimed for it. The shared pool is K *centroid vectors* and **no text**. A receiving agent therefore cannot read another user's note out of it, and we do not claim it can: verbatim knowledge transfer across users is *not* what this mechanism delivers, and any mechanism that did deliver it would be releasing the very artifact the attacks of §2 consume. What the pool *does* deliver is a **shared routing prior**: a fleet-level map of *which regions of memory space hold knowledge*, against which any agent can route a query — to the right local memory, the right tool, the right public corpus — without any note leaving its device. That is a narrower promise than "every agent inherits every fix," and it is the one our metric actually measures (evidence-recall: did the query

reach the bucket containing its evidence?). It is also the promise worth keeping: the coarse pool is exactly the part of shared memory that *can* be released under a guarantee, and §7.1 shows it is released nearly for free.

Why the obvious defenses are insufficient. Access-control layers (*Collaborative Memory* [13]) and on-device masking (*MemPrivacy* [14]) restrict *who* sees a note but provide no formal guarantee over the *aggregate*, and a curated central datastore [15] reintroduces a trusted party. What is missing is a mechanism that (a) needs **no trusted curator**, (b) gives a **central-DP guarantee over the shared pool**, and (c) is shown to actually **degrade the known attacks** while keeping the pool useful.

Our approach. We treat federated memory aggregation as a **secure summation of per-user bucketed embeddings**. Each user projects their notes to a working dimension d with a **public-seed random projection**, maps them into K shared buckets (random-hyperplane LSH), forms a per-bucket sum-vector, and contributes it through **SecAgg** [2] so the server sees only the masked sum; the **Skellam mechanism** [5] adds calibrated discrete noise that **composes under summation**, yielding a single distributed-DP guarantee on the pooled centroid memory. Retrieval is cosine lookup against the noised centroids. The cryptographic path is used **verbatim** from federated discrete-DP work; the novelty is the *payload* (agent-memory embeddings) and the *evaluation* (a measured attack-success drop).

Why this payload, and why now. Federated DP for LLM *adaptation* (DP-LoRA, prompt tuning) is saturated, and recent federated-privacy work for LLMs targets *other* objects, DP synthetic-data generation (POPri [16]) and privacy-constrained agent self-evolution (Fed-SE [17]), rather than the aggregation of a shared **memory** pool; contemporaneous agent-memory security surveys [18] catalogue attacks and access-control/redaction defenses but no curator-free DP aggregation mechanism. The nearest mechanism, *DP Datastore Generation* [15], privatises a retrieval datastore but in a **centralized, single-curator** setting with generic additive noise and no secure aggregation (§2). Federated agent-memory aggregation under SecAgg + discrete Skellam DP is thus an open seam. Crucially, agent-memory objects are **genuinely tiny-dimensional and often already discrete**, which is exactly the regime where the discrete Skellam mechanism is most efficient and where our dimension analysis is most credible.

Contributions.

1. **A federated agent-memory aggregation mechanism** that composes SecAgg with the Skellam mechanism over bucketed memory-note embeddings, giving a curator-free central-DP shared **routing prior** (§4–5).
2. **A joint utility/leakage frontier, and a positive endpoint on it.** We measure both axes **at every fidelity** K , which a two-axis claim requires and which our own superseded draft did not do (it reported utility only at $K \leq 256$ and leakage only at $K \geq 512$, so its two headline numbers described disjoint releases). On the frontier the coarse- K regime is usable *and* safe at one operating point: at $K=32$ the pool retains **95% of clean evidence-recall** at $\epsilon \approx 9.3$ while a calibrated offline-LiRA attack falls from **AUC 0.833 / TPR@1%FPR 0.175** to the **1% false-positive floor** (0.011), and reconstruction-decode from 0.771 to 0.396; at $K=128$ (72% retention) *both* attacks reach their floor (§7.1).

3. **A methodological result: the weak attack the literature defaults to is blind exactly where it matters.** The uncalibrated cosine proxy reads **0.504 — chance — at $K=32$** , on the same clean release the calibrated attack breaks at AUC 0.833. A proxy-only evaluation would therefore have certified a leaking pool as safe, and would have reported (as our superseded draft did) that leakage only exists in a sparse regime nobody would deploy. The endpoint is real; the proxy could not see it (§7.5).
4. **A negative result with teeth: the dimension "crossover" is an artifact of data-dependent preprocessing.** Fitting the projection on user notes is an unaccounted release *and* it fabricates the finding that tiny- d is jointly optimal for privacy and utility. Under a data-independent projection the effect reverses on the utility axis and vanishes on the leakage axis, with an identity-projection control ($d=384$) that all three projections must and do agree on (§7.4). We believe this confound is not specific to this paper.
5. **An end-to-end-accounted mechanism, including repeated release:** the projection, the LSH anchors, the clip bound C and the quantiser bound $B := C$ are all public or DP-selected, so the reported ϵ covers the entire pipeline rather than only its last stage (§5.2, §7.7); the clip-selection cost is 0.2% of the budget. Because agent memory is *re-aggregated* as users write notes, we also account for the T -round release a deployment actually performs: naive re-release is ruinous ($\epsilon\ 9.3 \rightarrow 93$ for a month of daily rounds), but the cost is $\sqrt{T}$ in the noise scale, so a **monthly cadence sustained for a year fits inside the same $\epsilon \approx 9.3$ at 81% retention** (§5.7).
6. **A rigorous, tightened accounting:** an exact Skellam-RDP ϵ for the discrete mechanism (Agarwal et al. Thm 3.5 [5]), a proof that **discretisation is free** at our resolution, and a **vector-only release** that dominates the two-channel design once bucket occupancy is accounted for (§5.3, §7.7, §7.11).
7. **A realistic-payload validation:** LLM-distilled A-MEM/Mem0-style notes leak *more* than raw turns, yet DP still collapses the attack to chance: the real payload strengthens, not weakens, the result (§7.6).

All results are reported as **5-seed means with final (not peak) metrics**; the harness and grid are released (§10).

2. Related Work

Federated DP with secure aggregation and discrete noise. SecAgg [2] lets a server compute a sum of client vectors without seeing any summand. To obtain a DP guarantee that composes under that sum without a trusted curator, discrete mechanisms are used: the **distributed discrete Gaussian** [6] and the **Skellam mechanism** [5], the latter being closed under addition (the sum of Skellams is Skellam) and efficient at low bit-width. Prior deployments target **gradient** payloads for model training. We reuse this path *verbatim* but change the payload to **agent-memory embeddings** and the objective to **retrieval**, not learning.

Privacy of LLM-agent memory. Agent frameworks A-MEM [9] and Mem0 [10] persist distilled per-user memories. Their privacy is under active attack: **MEXTRA** [11] extracts memory content and **MRMMIA** [12] runs membership inference; a memory-security survey [18] catalogues this attack literature. Defenses so far are **access control** (*Collaborative Memory* [13], which also introduces a shared-vs-private memory

split but governs *who reads* a note, not the aggregate) and **on-device masking / redaction** (*MemPrivacy* [14]); neither gives an aggregate formal guarantee. We therefore **cite and reuse the attacks as our evaluation harness** rather than claiming them, and provide the missing mechanism-side guarantee.

Federated retrieval / datastores (the nearest prior art). *DP Datastore Generation* [15] is the closest existing mechanism: it partitions data with **locality-sensitive hashing** and adds **calibrated DP noise to each bucket's aggregate**, releasing a private datastore on which membership-inference accuracy falls to near-chance ($\approx 53.6\%$ at $\epsilon=5$), the same LSH-bucket-plus-DP skeleton and privacy-endpoint framing we adopt. It is, however, **centralized and single-curator**, uses **generic additive (continuous) noise with no secure aggregation**, and its payload is a **classification/retrieval datastore**, not cross-user agent memory. Our delta is therefore fourfold: (i) a **federated, curator-free** release under **SecAgg**, where the noise is added distributively and no party ever sees a summand; (ii) the **Skellam** mechanism, whose **closure under summation** is precisely what makes the distributed release *equal* the intended central mechanism (a discrete-Gaussian/continuous-noise datastore does not compose this way under modular SecAgg); (iii) the **agent-memory embedding** payload and cosine-retrieval objective; and (iv) the coupled **dimension/density crossover** and the distilled-payload finding (§7.2, §7.4). **POPri** [16] is federated and private but produces **DP synthetic data via preference optimisation**, not an aggregated memory/preference pool, so it is orthogonal; **Fed-SE** [17] federates agent *self-evolution* under privacy constraints, adapting behaviour, not releasing a shared memory. To our knowledge no prior work aggregates cross-user agent memory under SecAgg + discrete-DP with a measured attack-drop endpoint.

Dimension dependence of DP. That utility degrades with dimension under DP is classical (Bassily–Smith–Thakurta [20]) and was sharpened for deep models by Chen et al. [19]. We do **not** claim the dimension dependence itself; our contribution is the **coupled crossover** (that in agent memory, dimension governs pre-DP *leakage* and DP *utility-retention simultaneously*, making tiny-d a joint optimum) and the demonstration on real memory embeddings.

3. Threat Model and Problem Setup

Parties. N users, each with a local agent holding a set of memory notes; an honest-but-curious aggregation server; and downstream agents that query the shared memory.

Goal. Produce a single **shared memory pool** (a set of K centroid embeddings) that any agent can query by cosine similarity to retrieve relevant knowledge contributed by the fleet, such that the pool carries a **central (ϵ, δ) -DP guarantee at user granularity** and no individual user's notes can be reconstructed or their membership inferred.

Trust / adversary. No trusted curator: under SecAgg the server observes only the masked sum, so the DP noise need not be added by a trusted party. The adversary is a recipient of the released pool (server or any downstream agent). It mounts:

- **Membership inference (MRMMIA analog):** given a candidate note embedding x , decide whether the user who owns x contributed to the pool. Score $s(x) = \cos(x,$

$\text{centroid}[\text{bucket}(x)]$; members pulled their own centroid and score higher. Metric: ROC-AUC (0.5 = no leakage).

- **Extraction (MEXTRA analog):** advantage in reconstructing an in-bucket member embedding from the centroid; we report the member/non-member **extraction gap**.

The vulnerable subpopulation. In a *sum* mechanism, leakage concentrates where **few users contribute to a bucket**: averaging already protects well-populated buckets, and distributed-DP noise is *most* protective exactly at the sparse tail. We therefore stratify every leakage metric by the **low-count tail** (buckets with ≤ 3 contributors), which is the honest worst case and the group agent-memory privacy actually cares about (rare/unique notes).

Threat boundary (what we do not defend). Our adversary is **passive**: a recipient of the released pool — the honest-but-curious server, or any downstream agent — and, under SecAgg, an observer of masked traffic. Two adversaries are explicitly out of scope. (i) **Active, colluding clients.** A malicious participant can inject structured notes to steer particular bucket centroids across epochs, and query the pool before and after a target user joins, turning the offline LiRA of §7.8 into an *adaptive online* attack against specific delta vectors. Robust aggregation against poisoning of a private vector-retrieval pool is an open problem, orthogonal to the release mechanism analysed here. (ii) **Participation metadata.** SecAgg hides a client's *contents*, not the fact that it participated; §5 specifies mandatory participation with padded dummy payloads to close that channel, an assumption we state but do not measure.

Utility. For a query q , retrieval routes to the top- k centroids by cosine; utility is whether the *right* content is retrieved (evidence-recall / answer-recall on real benchmarks, topic-accuracy on synthetic corpora).

4. Bucketed Centroid Memory

Let each note i of user u have embedding $e_i \in \mathbb{R}^D$ from a sentence encoder. We reduce to a working dimension d with a **public-seed Gaussian random projection** $P \in \mathbb{R}^{D \times d}$, $P_{\{jk\}} \sim \mathcal{N}(0, 1/d)$, L2-normalize, and assign to one of K buckets by random-hyperplane LSH: fix K random anchors $a_1 \dots a_K$ and set $\text{bucket}(i) = \arg\max_k \langle e_i, a_k \rangle$. Both P and the anchors are drawn from a **published seed and never touch user data**, so shipping them to clients releases nothing and the ϵ of §5.4 accounts for the *entire* pipeline. This is not a detail: a PCA fit on the users' notes — the obvious choice, and the one an earlier draft made — is a data-dependent release whose privacy cost is unaccounted, and §7.2 shows it also manufactures a spurious finding. Each user forms, per bucket k , a **sum-vector** $v_u[k] = \sum_{i: \text{bucket}(i)=k} e_i$ and a **count** $c_u[k]$. The (non-private) shared centroid is

$$\mu[k] := \text{normalize} \left(\frac{\sum_u v_u[k]}{\sum_u c_u[k]} \right).$$

Retrieval for query q returns the top- k buckets by $\cos(q, \mu[k])$. K controls memory *fidelity* (more buckets = finer memory), d controls embedding *resolution*; both, as we show, trade off against privacy.

5. Private Release: SecAgg + Skellam

Per-user clipping and quantisation. A user's contribution to the release is not one bucket but the *whole* payload: the concatenation $V_u = [v_u[1]; \dots; v_u[K]] \in \mathbb{R}^{K \cdot d}$. We therefore clip V_u **globally**, to a single L2 bound C , and only then quantise to integers on a fixed grid of resolution $s = \text{range_max} / B$ ($\text{range_max} = 1e6$, B the quantiser bound). This yields integer vectors amenable to SecAgg and to a discrete noise mechanism, with **user-level L2 sensitivity exactly** $\Delta_2 = C \cdot s$.

Neighbouring relation. Throughout, two datasets are neighbours if one is obtained from the other by **adding or removing a single user** (unbounded DP). This is what makes $\Delta_2 = C \cdot s$ exact: deleting a user removes one clipped payload of norm $\leq C$. (Under the *replace-one* convention the same mechanism would have $\Delta_2 = 2C \cdot s$, and every ϵ below would double.) We use the same relation for the clip-selection mechanism of §5.2, so the two costs compose against a single definition.

5.2 The clip bound is a mechanism parameter, so it must be public too

C and B are shipped to every client. The natural choice — C = the 95th percentile of the observed payload norms, B = the largest observed coordinate — is a **function of the private corpus**, so releasing it is an unaccounted release, exactly the error §7.2 diagnoses for the projection. An earlier draft of this paper made both. We fix both, and neither is expensive.

- **$B := C$ is free.** Since every note is L2-unit and the payload is clipped first, $|v_u[j]| \leq \|v_u\|_2 \leq C$ for every coordinate j . So $B := C$ is a *public* bound that provably never clips a coordinate, and ϵ is invariant to B anyway: $\Delta_2/\sqrt{\mu} = 1/\sigma$ regardless of $s = \text{range_max}/B$. Nothing is paid.
- **C is DP-selected.** We choose C from a public geometric grid with the **exponential mechanism** on the rank utility $u(c) = -|\#\{u : \|v_u\|_2 \leq c\} - q \cdot N|$, $q = 0.95$, sampling c with probability $\propto \exp(\epsilon_c \cdot u(c)/2)$. Its sensitivity under **add/remove** deserves care, because the count *and* the target $q \cdot N$ both move when a user leaves. Removing a user whose norm is $\leq c$ drops the count by 1 and the target by q , so the argument of $|\cdot|$ shifts by only $1 - q = 0.05$; removing a user whose norm is $> c$ leaves the count alone and shifts the target by q . Hence

$$\Delta u = \max(1 - q, q) = q = 0.95 \leq 1,$$

and the sampler above — which would be ϵ_c -DP at $\Delta u = 1$ — is in fact $(q \cdot \epsilon_c)$ -DP. We **charge the full ϵ_c** , a 5% conservative margin. It composes with the release in RDP via pure-DP $\rightarrow$ zCDP: an ϵ_c -DP mechanism is $(\epsilon_c^2/2)$ -zCDP, hence $\text{RDP}_\alpha \leq \alpha \cdot \epsilon_c^2/2$ [21]. (Had we instead assumed the replace-one convention here while using $\Delta_2 = C \cdot s$ for the release, the two mechanisms would have been accounted against different neighbouring relations — a subtle way to under-count.)

We spend $\epsilon_c = 0.1$, which costs **0.2% of the budget** (ϵ 9.29 $\rightarrow$ 9.31 at $\sigma=0.606$; §7.5). The grid is deliberately **coarse** (16 points spanning $[2, 64]$, a public range: a user with n_u unit-norm notes has $\|v_u\|_2 \in [\sqrt{n_u}, n_u]$, and agent memories hold tens of notes per user), because the exponential mechanism's rank error grows like $\log|\text{grid}| / \epsilon_c$.

The selection is conservative, and one-sidedly so. The rank utility saturates at $-0.05 \cdot N$ for any c above the largest observed norm, so at small ϵ_c the entire upper tail of the grid stays competitive and C is biased **upward**: on LongMemEval-oracle at $K=32$ it lands at 21.7 ± 8.5 against a true p95 of 13.7 ± 1.3 (mean ratio 1.6 $\times$). That error only ever *adds* noise — it can never under-noise the release — so the guarantee is safe, and the price is utility: evidence-recall@5 at $\epsilon \approx 9.3$ falls from 0.416 (leaky empirical p95) to **0.406** at $K=32$, and from 0.117 to 0.100 at $K=256$, where the signal-to-noise is thinner. We regard a 2% headline utility cost as the correct price for an accounted guarantee, and note the knob: $\epsilon_c = 0.25$ tightens C to 13.4 ± 1.3 and recovers most of the loss, at a total ϵ of 9.41 instead of 9.31.

Remark 1 (cross-bucket sensitivity: why the clip must be global). Clipping each bucket-vector *separately* to C would **not** yield sensitivity C . A user with notes in b_u distinct buckets would contribute up to C in each, so the payload sensitivity would be $\sqrt{(\sum_k \|v_u[k]\|^2)} \leq \sqrt{b_u} \cdot C$, and an accountant still charging $\Delta_2 = C \cdot s$ would under-count by $\sqrt{b_u}$. The blow-up is governed by $b_u \leq \min(n_u, K)$, the number of buckets the user *touches* — **not by K alone**, since a user with n_u notes cannot occupy more than n_u buckets. On LongMemEval-oracle (mean 21.9 notes/user, max 72) the busiest user touches $b_{\max} = 21$ buckets at $K=32$ and 54 at $K=1024$, so per-bucket clipping would have inflated the true budget from the reported **$\epsilon \approx 9.31$ to $\epsilon \approx 69$ ($K=32$) and $\epsilon \approx 159$ ($K=1024$)** — a broken guarantee. Our implementation clips globally (`clip_rows_to_norm(V_u.reshape(1, -1), C)` in `scripts/agentmem/_agentmem_leakage.py`), so every ϵ reported in this paper is sound; line 8 of Algorithm 1 makes this explicit.

Remark 1 (cross-bucket sensitivity: why the clip must be global). Clipping each bucket-vector *separately* to C would **not** yield sensitivity C . A user with notes in b_u distinct buckets would contribute up to C in each, so the payload sensitivity would be $\sqrt{(\sum_k \|v_u[k]\|^2)} \leq \sqrt{b_u} \cdot C$, and an accountant still charging $\Delta_2 = C \cdot s$ would under-count by $\sqrt{b_u}$. The blow-up is governed by $b_u \leq \min(n_u, K)$, the number of buckets the user *touches* — **not by K alone**, since a user with n_u notes cannot occupy more than n_u buckets. On LongMemEval-oracle (mean 21.9 notes/user, max 72) the busiest user touches $b_{\max} = 21$ buckets at $K=32$ and 47 at $K=1024$, so per-bucket clipping would have inflated the true budget from the reported **$\epsilon \approx 9.28$ to $\epsilon \approx 69$ ($K=32$) and $\epsilon \approx 140$ ($K=1024$)** — a broken guarantee. Our implementation clips globally (`clip_rows_to_norm(V_u.reshape(1, -1), C)` in `scripts/agentmem/_agentmem_leakage.py`), so every ϵ reported in this paper is sound; line 7 of Algorithm 1 makes this explicit.

Skellam noise, composed under the sum. Each user adds Skellam noise (difference of two Poissons, per-coordinate variance $\mu = (\sigma C s)^2$) to their quantised vector and submits it through **SecAgg**, so the server recovers only $\Sigma_u (\text{quantise}(\text{clip}(v_u)) + \text{Skellam})$. Because the sum of independent Skellams is Skellam, the *released sum* carries the target noise with **no trusted curator**. Dequantising and dividing by the (also-released or cancelled, §5.3) count gives the private centroid $\tilde{\mu}$.

Implementation constraints of the integer path. Three details the accountant assumes and an implementation must honour.

- *Modular field size.* SecAgg sums in a finite field $\mathbb{Z}_p$; too small a p and the integer sum wraps, silently corrupting the aggregate. Per coordinate the signal is bounded by $N \cdot \text{range_max}$ and the aggregate noise has standard deviation $\sigma_C s$, so it suffices that $p > 2 \cdot (N \cdot \text{range_max} + \kappa \cdot \sigma_C s)$ for a tail factor κ (we use $\kappa = 6$). At our operating point ($N=500$, $\text{range_max}=10^6$, $\sigma_C s = 8.4 \times 10^5$) this is $p > 10^9$. The reference implementation aggregates in `int64`, exceeding the bound by nine orders of magnitude; the measured peak coordinate of the noised aggregate is 1.8×10^7 . (The $\sqrt{d}$ that one might expect here does not appear: the constraint is per-coordinate.)
- *Mandatory participation and padding.* A client with no new notes must still submit. It forms the all-zero payload, adds its Skellam share (line 10) and its SecAgg mask, and submits a vector of identical shape. Because the noise is injected *before* masking, an idle client's submission is distributionally indistinguishable from an active one's, so neither the server nor a network observer learns who used their agent this epoch. Uniform payload shape likewise prevents inferring that a user's memory is narrow (few occupied buckets) from the ciphertext.
- *Rounding, and what clipping does to heavy users.* `round(v · s)` can lift the integer norm above $C \cdot s$ by at most $\sqrt{Kd}/2$: at our operating point 16 against $\Delta_2 = 1.39 \times 10^6$, a 10^{-5} relative inflation, which we absorb rather than adopt the conditional randomised rounding of [6]. Note also that the clip of line 7 is a **scalar rescale**: it shrinks a heavy user's magnitude but leaves the direction of v_u exactly unchanged, so a high-activity user's semantics are *down-weighted, never distorted*. A deployment that wishes to bound that down-weighting can cap notes-per-user before aggregation, which lowers `C` and hence the absolute noise.

5.3 Vector-only release, and what the count channel is (and is not) for

The natural design releases **two** channels (the sum-vector and the counts), costing two RDP compositions. For the *direction* of the retrieval centroid the count is redundant: dividing by the scalar count and L2-normalising cancels it, `normalize(sv/sc) = normalize(sv)`. The count therefore never affects the ranking *among the buckets we keep*, and releasing its magnitude is strictly wasteful. We release **only the summed vector** (one composition): identical retrieval to the last decimal at **~1.5× tighter ϵ** (§7.5). We call this the *vector-only* release.

What the count channel was silently doing: occupancy. Normalisation is not innocent for a bucket nobody filled. If bucket `k` has no contributors then `S[k]` is *pure Skellam noise*, and line 18 of Algorithm 1 projects it onto the unit sphere — manufacturing a random unit vector that competes for top-`k` slots against genuine centroids. Cosine ranking cannot tell the two apart, so a release that keeps empty buckets can be flooded with false positives. **Count magnitude cancels; occupancy does not.** Three facts make this precise (all measured in §7.10):

1. **It does not arise at the operating points.** With 10,957 notes over 500 users, **no bucket is empty for `K ≤ 128` on any seed**, and $0.23 \pm 0.19\%$ at `K = 256` (at most one bucket of 256). Every

retrieval number in this paper is reported at $K \leq 256$, and the recommended point is $K = 32$. The noisy-normalisation failure mode is therefore **absent from the reported utility**, not tuned away.

2. **Where it does arise, occupancy is expensive to release.** Under **user-level** DP a count channel is *not* the cheap sensitivity-1 object it would be under note-level DP: deleting a user erases *all* of its entries at once. Even a **binary user-indicator** channel — the cheapest sensible variant, since a user contributes 0/1 per bucket — has L2 sensitivity $\sqrt{b_u}$ ($\approx 5\text{--}8$ here, and its DP-selected public bound lands at 9.7–12.4), **not 1**. The indicator channel is nonetheless the right one: at a full second composition ($\sigma_c = \sigma_v$, ϵ 9.31 $\rightarrow$ 13.94) it detects empty-vs-occupied at AUC **0.87 / 0.76 / 0.70** for $K = 512 / 1024 / 2048$, against **0.82 / 0.68 / 0.63** for raw counts. Made cheap ($\sigma_c = 2$, $\epsilon = 9.78$) it falls to **0.72 / 0.59 / 0.55**. Thresholding the released vector's own norm $\|S[k]\|$ against the analytic noise floor $\sigma_c \sqrt{d}$ is **free** (post-processing) but is at **chance**: AUC 0.50 / 0.49 / 0.48.
3. **The difficulty is intrinsic, not an implementation shortfall.** At the densities where buckets are near-empty, the noise that drives membership inference to chance in a one-contributor bucket (§7.3) is *the same noise* that hides whether the bucket has a contributor at all. **Occupancy and membership are the same signal**; no mechanism hides the member and reveals the bucket.

We therefore state the claim precisely: **vector-only dominates the two-channel design at a fixed occupancy rule**, and at the recommended K that rule is vacuous because no bucket is empty. The sound response to a high- K deployment is to *increase density* (coarsen K , which also maximises retention, §7.1), not to bolt on a count channel that cannot pay for itself.

No occupancy oracle in the reported numbers. For the leakage measurement (§7.3, §7.4b, §7.7b) we release the **vector-only** memory with *no* occupancy suppression: $\mu[k] = \text{normalize}(S[k])$ for every bucket, so an empty bucket carries normalized Skellam noise and nothing reads the clean counts. This is the recommended mechanism of §5.3, and it removes the non-private gate an earlier draft used. It does not change the conclusion — dropping the gate moves every tail-AUC by ≤ 0.003 (5-seed), inside the noise, because a member always occupies its own bucket and a non-member in an empty bucket scores against noise either way — but it means the §7.3/§7.4b/§7.7b tables contain no oracle step. The only clean-count quantity that survives is the **tail stratification** (≤ 3 contributors), which is a property of our *evaluation lens*, not of the release: the adversary never sees it, and it selects which rows of results we report rather than what the mechanism emits. The occupancy *rule* a dense high- K deployment would need for retrieval is a separate question, priced in §7.10.

5.4 Privacy accounting (exact Skellam-RDP)

We account with the exact discrete guarantee of Agarwal, Kairouz & Liu (NeurIPS 2021, Thm 3.5) [5]:

$$\epsilon_{\text{RDP}}(\alpha) \leq \frac{\alpha \Delta_2^2}{2\mu} + \min\left\{\frac{(2\alpha-1)\Delta_2^2 + 6\Delta_1^2}{4\mu^2}, \frac{3\Delta_1^2}{\mu}\right\},$$

with μ the per-coordinate released variance, $\Delta_2 = C s$, $\Delta_1 \leq \sqrt{d} \cdot \Delta_2$. Composition over releases is additive in RDP; we convert to (ϵ, δ) by $\epsilon = \min_{\alpha} [\text{RDP}(\alpha) + \ln(1/\delta)/(\alpha-1)]$ ($\delta = 1e-5$). This is implemented as `skellam_rdp_epsilon(...)` in `qpriviot_fl/privacy_utils.py` and replaces the approximate single-shot Gaussian labels used during exploration. **Every ϵ in this paper is the rigorous Skellam-RDP value.** A representative mapping at the $K=32, d=32$ operating point:

σ	classic (invalid $\epsilon > 1$)	Skellam, vector-only (1 release)	Skellam, two-channel (2 releases)
0.303	15.99	22.11	33.31
0.606	7.99	9.30	13.94
1.615	3.00	3.21	4.63
2.854	1.70	1.81	2.56

Every ϵ above is the **total**: the Skellam release plus the $\epsilon_c = 0.1$ spent DP-selecting the clip bound (§5.2). The projection and $B := C$ contribute nothing.

The exploration labels " $\epsilon=8 / \epsilon=3$ " correspond to the rigorous $\epsilon \approx 9.3 / \epsilon \approx 3.2$ under the recommended vector-only release, clip selection included; we use those rigorous values throughout. Because all utility and leakage effects are **monotone in σ** , re-labelling the ϵ axis leaves every ordering, retention %, and AUC-drop unchanged.

On the choice of δ . The guarantee is at **user** granularity, so the population size that δ must be compared against is the number of **users** ($N = 500$), not the number of notes — the s -variant of \$7.7 has 246,073 *notes* contributed by those same 500 users. The standard requirement is $\delta \ll 1/N$: here $1/N = 2 \times 10^{-3}$, so $\delta = 10^{-5}$ sits **200× below** the threshold, comfortably inside the safe regime. The requirement *tightens* with the user count rather than relaxing, so scale is the stress case, not the reassurance: a production fleet of $N = 10^5\text{--}10^6$ **users** would need $\delta \ll 10^{-5}$. Our accountant takes δ as a parameter, and the cost of retightening is mild — at fixed σ , $\epsilon \approx 9.30 \rightarrow 10.07 / 10.84 / 11.44$ for $\delta = 10^{-6} / 10^{-7} / 10^{-8}$ (and $\epsilon \approx 3.21 \rightarrow 3.50 / 3.76 / 4.01$). Three orders of magnitude in δ cost **< 23% in ϵ** , so the mechanism carries to production-scale δ without re-tuning.

5.5 The full mechanism (algorithm)

We consolidate §4–5.3 into a single end-to-end procedure. The **shared public parameters** are the random-hyperplane LSH anchors $\{a_1, \dots, a_K\}$, the public-seed random projection $P: \mathbb{R}^D \rightarrow \mathbb{R}^d$, the clip bound C , the quantiser bound B and step $s = \text{range}_{\max}/B$, the noise scale σ , a **survival floor** $M_{\min}$ (§5.6), and the clip-selection budget ϵ_c (§5.2; the clip bound C and the quantiser bound $B := C$ are derived once, publicly, from it). The target per-coordinate *aggregate* Skellam variance is $\mu = (\sigma C/s)^2$; under SecAgg each client injects a $1/M_{\min}$ share, so the masked integer sum realises at least μ with **no trusted curator** and **no summand in the clear**. Only the **sum-vector channel** is released (§5.3): dividing by the count and L2-normalising cancels the count.

Algorithm 1 Private Federated Memory Aggregation (SecAgg + Skellam, vector-only release)

Public/shared: LSH anchors $a_1..a_K \in \mathbb{R}^d$; random projection $P: \mathbb{R}^D \rightarrow \mathbb{R}^d$
(public seed) ;

noise scale σ ; clip-selection budget ϵ_c ; target δ ;
survival floor $M_{\min} \leq N$ (§5.6; $M_{\min} = N$ under full

participation).

SERVER, ONCE (public parameters; §5.2)

0: $C \leftarrow \text{ExpMech}_{\{\epsilon_c\}}(\text{public grid}, u(c) = -|\#\{u : \|V_u\|_2 \leq c\} - 0.95 \cdot N|)$ $\triangleright$ DP-
selected clip bound

0': $B := C$; $s \leftarrow \text{range_max} / B$ $\triangleright$ public quantiser bound;

$|\text{coord}| \leq \|V_u\|_2 \leq C$

Aggregate per-coordinate variance $\mu = (\sigma \cdot C \cdot s)^2$.

CLIENT u (runs locally; note text never leaves the device)

1: for each note i of user u :

2: $e_i \leftarrow \text{normalize}(P(\text{Encoder}(\text{note}_i)))$ $\triangleright$ 384-d $\rightarrow$ d ,

then L2-unit

3: $b(i) \leftarrow \text{argmax}_k \langle e_i, a_k \rangle$ $\triangleright$ random-

hyperplane LSH bucket

4: for each bucket $k = 1..K$:

5: $v_u[k] \leftarrow \sum_{\{i : b(i)=k\}} e_i$ $\triangleright$ per-bucket

sum-vector

6: $V_u \leftarrow [v_u[1] ; \dots ; v_u[K]] \in \mathbb{R}^{\{K \cdot d\}}$ $\triangleright$ the user's

FULL payload

7: $V_u \leftarrow V_u \cdot \min(1, C / \|V_u\|_2)$ $\triangleright$ GLOBAL L2 clip

$\Rightarrow \Delta_2 = C \cdot s$

(per-bucket $\Rightarrow$

$\sqrt{b_u \cdot C}$: Remark 1)

8: for each bucket $k = 1..K$:

9: $z_u[k] \leftarrow \text{round}(v_u[k] \cdot s) \in \mathbb{Z}^d$ $\triangleright$ quantise; $B :=$

C never clips

10: $\tilde{n}_u[k] \leftarrow \text{Skellam}(\mu / M_{\min})$ $\triangleright$ noise share,

sized to survivors

$= \text{Poisson}(\mu / 2 \cdot M_{\min}) - \text{Poisson}(\mu / 2 \cdot M_{\min})$

11: $\tilde{z}_u[k] \leftarrow z_u[k] + \tilde{n}_u[k]$ $\triangleright$ integer-domain

DP noise

12: $m_u[k] \leftarrow \tilde{z}_u[k] + \text{mask}_u[k]$ ($\sum_u \text{mask}_u[k] = 0$) $\triangleright$ SecAgg zero-

sum mask

13: submit $\{m_u[k]\}_{k=1..K}$ to server

SERVER (honest-but-curious; sees only masked sums; $M \geq M_{\min}$ clients survive, else ABORT)

14: for each bucket $k = 1..K$:

15: $S[k] \leftarrow \sum_{\{u : \text{survived}\}} m_u[k] = \sum_u \tilde{z}_u[k]$ $\triangleright$ masks cancel

exactly

16: $= \sum_u z_u[k] + \text{Skellam}((M / M_{\min}) \cdot \mu)$

17: if $\text{occupancy_rule}(k) = \text{EMPTY}$: $\mu[k] \leftarrow 0$; continue $\triangleright$ §5.3: suppress

noise-only buckets

18: $\mu[k] \leftarrow \text{normalize}(\text{dequantize}(S[k])) = \text{normalize}(S[k] / s)$ $\triangleright$ count

cancels (§5.3)
19: release private centroid memory { $\mu[k]$ }_{k=1..K}

RETRIEVAL (any downstream agent, query q)
20: $\hat{q} \leftarrow \text{normalize}(P(\text{Encoder}(q)))$
21: return top-k buckets by $\cos(\hat{q}, \mu[k])$ over { $k : \mu[k] \neq 0$ }

ACCOUNTING (§5.4, exact Skellam-RDP; Agarwal et al. Thm 3.5)
22: $\Delta_2 \leftarrow C \cdot s$; $\Delta_1 \leftarrow \sqrt{d} \cdot \Delta_2$ ▷ valid *because* line 7
clips the payload globally
23: $\epsilon_{\text{RDP}}(\alpha) = \alpha \cdot \Delta_2^2 / (2\mu) + \min\{ ((2\alpha-1)\Delta_2^2 + 6\Delta_1) / (4\mu^2), 3\Delta_1 / (2\mu) \} + \alpha \cdot \epsilon_c^2 / 2$
▷ last term: DP clip
selection (line 0), zCDP bound
24: $\epsilon = \min_{\alpha} [\epsilon_{\text{RDP}}(\alpha) + \ln(1/\delta) / (\alpha-1)]$ ▷ 1 release (vector-only) $\Rightarrow$
 $\sim 1.5\times$ tighter ϵ

Why each step matters. Lines 2–3 place a note in the *shared* coordinate frame so different users' notes land in comparable buckets; both P and the anchors come from a public seed, so this step is data-independent and free (§4, §7.2). Lines 6–7 are the DP sensitivity: the clip is applied **once, to the concatenated payload**, because a user who touches b_u buckets would otherwise contribute C to each and the true sensitivity would be $\sqrt{b_u} \cdot C$ (Remark 1). Line 0 fixes the two public bounds before any user data is touched in the clear: C by the exponential mechanism (cost ϵ_c , 0.2% of the budget) and $B := C$ for free. Lines 9–11 move to the integer domain and add the discrete noise *there*, which is what makes it survive modular SecAgg. Line 12 masks the contribution; line 15 shows the masks cancel so the server learns only the sum. Line 16 is the crux: because the sum of independent Skellams is Skellam, the per-client $\mu/M_{\min}$ shares **compose to at least the central target μ** , so the distributed release *equals* (or, on good turnout, exceeds) the intended central mechanism — a property a continuous-Gaussian datastore lacks under modular arithmetic. Line 17 is the occupancy rule of §5.3; line 18 is the free win. The implementation is

```
apply_distributed_skellam_noise / skellam_noise / generate_zero_sum_masks /
quantize in qpriviot_fl/privacy_utils.py, and the accounting (lines 22–24) is
skellam_rdp_epsilon(...).
```

5.6 Client dropout: the noise floor must be sized to survivors, not to N

Line 10 injects a $1/M_{\min}$ share rather than the naive $1/N$, and the difference is not cosmetic. SecAgg deployments lose clients mid-protocol. If each of N clients injects $\text{Skellam}(\mu/N)$ and only $M < N$ survive to reconstruction, the server recovers aggregate variance μ_{actual} $= (M/N) \cdot \mu$ — an **effective noise multiplier** $\sigma_{\text{eff}} = \sigma \sqrt{M/N}$. The guarantee then degrades silently, and worst exactly when participation is worst:

survivors M/N	1.00	0.90	0.70	0.50	0.25
true ϵ (nominal $\epsilon \approx 9.30$)	9.30	9.91	11.61	13.94	22.11
true ϵ (nominal $\epsilon \approx 3.21$)	3.21	3.39	3.87	4.63	6.74

Two sound remedies, either of which restores a valid guarantee:

- **Calibrate to a survival floor $M_{\min}$** (Algorithm 1, line 10). Each client injects $\mathcal{M}(\mu/M_{\min})$, so any turnout $M \geq M_{\min}$ realises variance $(M/M_{\min})\mu \geq \mu$: the guarantee **can only improve**, never degrade, and the server **aborts** rather than releasing if $M < M_{\min}$. The price is over-noising on good turnout. With $M_{\min} = N/2$ calibrated to $\epsilon \approx 9.30$ *at the floor*, a full-turnout round realises $\sigma = 0.857$ and $\epsilon \approx 6.31$ — utility is paid for at the floor, privacy is banked at the ceiling.
- **Fault-tolerant distributed noise generation.** Secret-share each client's noise seed exactly as SecAgg already secret-shares its mask seeds [2], so surviving clients reconstruct the dropped clients' noise shares and the aggregate variance is exactly μ for any M . This removes the utility penalty at the cost of another reconstruction round.

Our experiments assume full participation ($M = N = 500$, i.e. $M_{\min} = N$): a single-round, single-shot release with no straggler model. Dropout robustness is therefore something this paper *specifies* but does not *measure*; we record it as a limitation (§8), not a claim.

5.7 Repeated release: memory is re-aggregated, so the budget must compose

A model is trained once; a **memory** is not. Users write notes continuously, and a deployed pool is re-aggregated on some cadence — which means the release of §5.5 happens T times, not once, and **the guarantee that matters is the composed one**. This is the assumption most easily left implicit, and leaving it implicit is not benign: RDP composes *additively*, so re-releasing at the single-shot $\sigma = 0.606$ costs $\epsilon \approx 22 / 44 / 93 / 153$ for $T = 4 / 12 / 30 / 52$. A mechanism advertised at $\epsilon \approx 9.3$ and re-run nightly is not an $\epsilon \approx 9.3$ mechanism.

The remedy is not to release once and hope. Because the composed RDP is linear in T while the per-release RDP falls as $1/\sigma^2$, the noise needed to hold a **fixed total budget** grows only as $\sqrt{T}$, so a cadence can simply be *bought* up front: pick the T the deployment needs, solve for σ , and pay for it once in utility. The table below (regenerated in the bottom cell) prices that trade at the recommended $K=32$, reading retention off runs actually executed at each σ rather than extrapolating.

The headline is that the mechanism **survives a realistic cadence**: a pool re-aggregated **monthly for a full year** — twelve releases, each incorporating every note written since the last — costs **81% retention at the same $\epsilon \approx 9.3$** we report throughout, against 95% for the single shot. Even a month of *daily* re-aggregation holds 73%. What a deployment may **not** do is re-release at the single-shot σ and continue to quote the single-shot ϵ .

Two properties make this cheaper than it first looks. The **public parameters do not recompose**: the projection and anchors are public-seed (zero ϵ at any T), and the clip bound C is a *public* bound over the payload norm, so it is selected once and reused — we charge ϵ_c a single time, not T times. And the guarantee is **user-level and unbounded-DP**, so a user who writes no notes between rounds contributes an all-zero payload and their privacy is not re-spent by the calendar; it is the *release* that composes, not

the user. Sizing σ to the planned horizon and aborting past it is the sound discipline, exactly as `M_min` is for turnout (§5.6).

6. Experimental Setup

Datasets / payloads.

- **LongMemEval (oracle)** [8]: real long-horizon conversational memory. Users = question haystacks, notes = dialogue turns, queries = questions, ground truth = evidence turns. The loader yields **500 users, 10,957 note embeddings, 479 queries with evidence**.
- **LongMemEval (s)** [8]: the full-haystack variant, same 500 users but **246,073 note embeddings** (~96% distractors), $\sim 22\times$ the oracle corpus, used for the at-scale generality check (§7.7).
- **LLM-distilled notes** (A-MEM/Mem0-style): dialogue turns distilled into memory notes by a local LLM (Ollama `qwen2.5:7b`). **500 users $\rightarrow$ 6,116 distilled notes**; a 100-user pilot $\rightarrow$ 1,715 notes. This is the realistic agent-memory payload, and the memory store for the live-agent attacks of §7.9.
- **Synthetic / real-embedding controls**: 20-Newsgroups with TF-IDF $\rightarrow$ SVD and with real `all-MiniLM-L6-v2` embeddings, for controlled `N / K / d` sweeps and a clean topic-accuracy metric.

Embeddings. `all-MiniLM-L6-v2` (384-d) [7], reduced to the working dimension `d` by a **public-seed Gaussian random projection** (data-independent; §4). Buckets are `K` random-hyperplane anchors from the same public seed. For the §7.2 ablation only, we additionally run two alternatives: `data-PCA` (PCA fit on the users' notes — the unaccounted release) and `publicPCA` (PCA fit on a disjoint public corpus: 20-Newsgroups for the LongMemEval runs, LongMemEval for the 20NG runs). At `d=384` the projection is the identity, which is the ablation's control. Selected by `--proj {randproj,pca,publicpca}`.

Mechanism. Faithful crypto path (`privacy_utils` `quantize` $\rightarrow$ Skellam $\rightarrow$ SecAgg-sum $\rightarrow$ dequantize), `range_max = 1e6`. Vector-only release unless stated. The clip bound `C` is DP-selected once per run with the exponential mechanism at `ε_c = 0.1` (§5.2, `--clip-eps`), and the quantiser bound is `B := C`; both are public parameters of the released mechanism and their cost is inside every ϵ we report.

Metrics.

- *Utility*: evidence-recall@5 (LongMemEval), answer-recall@5 (distilled), topic-accuracy (controls); chance $\approx \text{topk}/K$. We report **retention@ ϵ = utility(ϵ)/utility(clean)**.
- *Leakage*: membership-inference ROC-AUC and **low-FPR TPR** (calibrated LiRA, §7.8) over all buckets and the **low-count tail** (≤ 3 contributors), a reconstruction-decode extraction rate (§7.8), and, against a live agent (§7.9), MEXTRA verbatim-recovery and MRMMIA-AUC. $0.5 \text{ AUC} / \text{TPR} \approx \text{FPR} / \text{chance-level decode} = \text{no leakage}$.

Protocol. 5 seeds (0–4), final metric (not peak), mean $\pm$ std; the calibrated LiRA of §7.8 uses 3 seeds $\times$ 48 shadow releases and the live-agent attacks of §7.9 run on `qwen2.5:7b`. Members vs non-members are a same-distribution split of the note pool (aggregated vs held-out), avoiding any train/test confound.

Status (all runs complete). Every §7 table is regenerated from the **random-projection** grid (`experiment_results/rerun_grid_rp` , `rerun_grid_s_rp` , `lira_rp`) by the

code cell at the end of this notebook. The oracle grid, the at-scale **s -variant** (246k notes, \$7.7), the **LLM-distilled payload** (\$7.4), the **calibrated offline-LiRA + reconstruction-decode** attacks (\$7.8), and the **end-to-end published MEXTRA/MRMMIA attacks against a live agent** (\$7.9) are all done; no result is pending. The superseded data-PCA grid is retained *only* as the \$7.2 ablation baseline.

7. Results

All numbers below are regenerated from the released grid by the bottom cell, so the prose and the tables cannot drift. ϵ values are the rigorous Skellam-RDP labels of \$5.4, **including** the ϵ spent DP-selecting the clip bound (\$5.2), where the exploration labels " $\epsilon=8$ / $\epsilon=3$ " mean $\epsilon \approx 9.3$ / 3.2 . Seed noise on these corpora is **not** negligible (evidence-recall@5 carries a 5-seed std of ± 0.02 – 0.06), so we report it in every cell and avoid reading differences smaller than it.

7.1 The joint frontier: both axes, one operating point

A privacy/utility claim is a claim about *one release*. It is therefore only meaningful if both axes are measured at the **same** operating point — and this is precisely the discipline our own superseded draft failed. That draft measured utility only at $K \leq 256$ and leakage only at $K \geq 512$: two disjoint grids, from which it quoted "95% retention" (a $K=32$ number) and "tail-AUC 0.93 $\rightarrow$ 0.53" (a $K \geq 512$ number) as though they described a single mechanism. **They did not.** We therefore re-ran the missing cells — utility at $K \geq 512$, and the calibrated attack of \$7.2 at $K \leq 256$ — and report the **joint frontier**.

Three readings, all load-bearing.

1. **DP defeats the calibrated attack at every K .** LiRA AUC lands in 0.502–0.505 and TPR@1%FPR in 0.011–0.013 — the false-positive floor — for all seven fidelities, even as the *clean* attack climbs from AUC 0.833 to 0.998. The privacy axis is therefore **flat**: it does not trade against K . Choosing K is a pure utility decision, which is what makes the frontier readable.
2. **So the operating point is set by retention, and coarse wins.** Retention falls monotonically 95 $\rightarrow$ 86 $\rightarrow$ 72 $\rightarrow$ 60 $\rightarrow$ 41 $\rightarrow$ 25 $\rightarrow$ 15% as K grows 32 $\rightarrow$ 2048, because utility is set by *effective contributors per bucket*: coarse buckets pool more users, so DP is nearly free; fine buckets starve, so noise bites. **$K=32$ is the recommended point**: 95% retention with the membership attack at the floor.
3. **Membership and reconstruction do not die at the same K , and we say so.** At $K=32$ the *membership* attack is fully defeated (TPR@1%FPR 0.175 $\rightarrow$ 0.011) but *reconstruction-decode* only halves (0.771 $\rightarrow$ 0.396, against a noise floor of ≈ 0.08 measured at $\epsilon \approx 1.1$). This is not noise: at coarse K a centroid averages ~ 340 notes, so "the top-1 decoded note is a true in-bucket member" remains partly achievable simply because the bucket is large — the attack recovers a note's *region*, not its owner, and the disclosure is membership in a 340-note bucket rather than identification of a user. It is nonetheless above floor, and a deployment that must defeat reconstruction as well should

run at **K=128**, where decode reaches 0.070 (at floor) and membership stays at 0.011, for **72% retention**. We report both points rather than quoting the more flattering one.

The honest summary of the frontier is therefore: *the privacy axis is free across the whole sweep; pick K for the retrieval fidelity you need, and pay the retention it costs.* **K=32** if membership is the threat (95%); **K=128** if reconstruction is too (72%). What one may **not** do — and what the superseded draft did — is read utility off one end of this table and leakage off the other.

7.2 Calibrated attack: LiRA membership inference + extraction

The similarity scores in §7.2–7.4 embody the *measurement principle* of MEXTRA/MRMMIA but are a weak, uncalibrated proxy. We now run the **modern MIA standard** against the released pool: an **offline LiRA** (Carlini et al., S&P 2022) that, for each candidate note, estimates its membership-score distribution when it is *aggregated into* vs *held out of* the pool from many **shadow releases** (cheap here: our aggregation is numpy, not model training) and tests with the per-target likelihood ratio. We report **ROC-AUC and the low-FPR TPR** (the operationally meaningful metric that AUC-only proxies hide), plus a **reconstruction-decode extraction** attack (MEXTRA analog): decode each released centroid to its nearest note and score a hit when the top-1 decoded note is a true in-bucket member. Fits use a shadow split disjoint from the evaluation shadows (no train-on-test bias).

The clean release is far more leaky than the proxy revealed, and DP still defeats the strong attack (LongMemEval oracle, $d=32$, 3 seeds $\times$ 48 shadow releases):

K	release	AUC	TPR@1%FPR	TPR@0.1%FPR	decode-extract
1024	clean	0.997	0.945	0.784	0.912
1024	$\epsilon \approx 9.3$	0.504	0.013	0.001	0.003
1024	$\epsilon \approx 3.2$	0.501	0.012	0.002	0.001

Calibration exposes what cosine-AUC missed: on the clean pool an adversary re-identifies members at **$\approx 95\%$ true-positive rate at a 1% false-positive budget** and reconstructs the correct in-bucket note for **91% of centroids**: the untreated shared memory is almost fully de-anonymising. The Skellam release drives the same attack to **chance on every axis at once**: AUC **0.997** $\rightarrow$ **0.504**, TPR@1%FPR **0.945** $\rightarrow$ **0.013** (the FPR floor), and **extraction 0.912** $\rightarrow$ **0.003**. Note that the calibrated attack lands at 0.504 where the uncalibrated cosine proxy of §7.3 still reads 0.53–0.55: the proxy's residual was an artifact of its own weakness, not a real membership signal.

The effect holds across the fidelity sweep: clean leakage rises with **K** exactly as §7.3 predicted, while DP pins every cell at chance:

K	clean TPR@1%FPR	$\epsilon \approx 9.3$ TPR@1%FPR	clean decode	$\epsilon \approx 9.3$ decode
512	0.874	0.013	0.874	0.007
1024	0.945	0.013	0.912	0.003

K	clean TPR@1%FPR	$\epsilon \approx 9.3$ TPR@1%FPR	clean decode	$\epsilon \approx 9.3$ decode
2048	0.957	0.012	0.928	0.001

This LiRA is scored **per candidate note over all buckets**, not only the sparse tail: the TPR@1%FPR of 0.945 above is the all-bucket figure. It therefore already covers the *dense*-bucket case in which a single distinctive note pulls a centroid otherwise averaged over dozens of predictable "bystander" contributors — the likelihood ratio is computed against shadow releases with and without that exact note, so a unique contribution buried among benign ones is precisely what the test is powered to detect. Sparse-tail stratification (§7.3) reports where leakage *concentrates*; it does not bound where we *looked*.

On **real all-MiniLM-L6-v2 embeddings** the calibrated attack corroborates §7.2's negative result: under the data-independent projection clean TPR@1%FPR is nearly **flat** across dimension, **0.967** → **0.979** for $d=32 \rightarrow 384$ (decode 0.895 → 0.966), where the superseded data-PCA grid showed a steep 0.908 → 0.979. Tiny- d buys essentially no leakage reduction once the projection stops pre-anonymising the corpus, and DP collapses every cell to chance at $\epsilon \approx 9.3$ regardless of d (TPR@1%FPR 0.011 / 0.010). (We headline the low-FPR TPR because AUC becomes an unstable estimator at the largest σ , where it can tick up to ≈ 0.59 even as TPR@1%FPR stays at the $\approx 1\%$ floor; the attack is defeated operationally regardless.) This **upgrades the endpoint from a proxy to a calibrated attack**, leaving only the *LLM-agent-prompting* form of MEXTRA/MRMMIA (a live agent querying a text store, a different release model than our centroid pool) as future work.

7.3 Utility in detail (LongMemEval oracle)

Retrieval survives DP in the coarse- K regime and degrades gracefully as memory fidelity K grows (evidence-recall@5, $d=32$, vector-only release):

K	chance	clean	$\epsilon \approx 9.3$ (was $\epsilon=8$)	$\epsilon \approx 3.2$ (was $\epsilon=3$)	retention@ $\epsilon \approx 9.3$
32	0.156	0.428 ± 0.046	0.406 ± 0.054	0.363 ± 0.059	95%
64	0.078	0.320 ± 0.045	0.276 ± 0.049	0.217 ± 0.046	86%
128	0.039	0.233 ± 0.031	0.167 ± 0.039	0.124 ± 0.029	72%
256	0.020	0.167 ± 0.022	0.100 ± 0.035	0.057 ± 0.031	60%

At the recommended operating point (**$K=32$, $d=32$**) the private pool keeps **95%** of clean evidence-recall at $\epsilon \approx 9.3$ and **85%** at $\epsilon \approx 3.2$, at **2.7×** chance. Utility is set by *effective contributors per bucket*: coarse buckets pool more users, so DP is nearly free; fine buckets starve, so noise bites.

The d -sweep at fixed $K=128$ shows **no dimension penalty**: retention is **72% → 77% → 73%** for $d = 32 \rightarrow 64 \rightarrow 128$, flat within seed noise. Under the data-dependent PCA this same sweep read 78% → 67% → 55%, which is what the superseded draft reported as a dimension effect. §7.2 explains why.

 Evidence-recall@5 vs privacy budget for $K=32/64/128/256$ on LongMemEval oracle.

Figure 1. Retrieval utility vs privacy budget (LongMemEval oracle, $d=32$). At coarse $K=32$ the private pool tracks the clean curve (95% retention at $\epsilon \approx 9.3$) while higher-fidelity K starves buckets and DP noise bites. Dotted lines mark per- K chance. Error bars are 5-seed std.

7.4 The dimension "crossover" is an artifact of the projection

An earlier draft of this paper reported a **dimension/density crossover**: growing d appeared to *simultaneously* raise pre-DP leakage and lower DP utility-retention, making tiny- d Pareto-preferred and, apparently, a free lunch. That finding does not survive an honest projection, and the way it fails is instructive.

The projection P was a PCA **fit on the users' own notes**. That is a data-dependent release: P is handed to every client as a public parameter while being a function of private data, so the ϵ of §5.4 covered only the second stage. We therefore re-ran the entire d -sweep under three projections — the original **data-PCA**, a public-seed Gaussian **randproj**, and **publicPCA** (PCA fit on a disjoint public corpus) — holding **everything else fixed**, including the DP clip bound of §5.2. At $d=384$ the projection is the **identity**, so all three arms must coincide: that is the control, and they do (0.161 / 0.989).

(a) Private utility (topic-acc @ $\epsilon \approx 9.3$, real **all-MiniLM-L6-v2**, $N=100$, $K=32$; higher is better):

d	data-PCA (leaky)	randproj (free)	publicPCA (free)
32	0.308	0.151	0.147
64	0.285	0.178	0.150
128	0.240	0.158	0.142
384 (<i>identity</i>)	0.161	0.161	0.161

(b) Leakage (clean tail-AUC at $K=1024$; 0.5 = no leakage):

d	data-PCA clean	randproj clean	publicPCA clean	data-PCA $\epsilon \approx 9.3$	randproj $\epsilon \approx 9.3$
32	0.944	0.988	0.975	0.522	0.499
64	0.969	0.991	0.985	0.513	0.500
128	0.985	0.992	0.991	0.540	0.545
384 (<i>identity</i>)	0.989	0.989	0.989	0.541	0.541

Both halves of the crossover dissolve. On the **utility** axis, tiny- d wins by 91% under data-PCA (0.308 vs 0.161 at the identity) and is the **worst** choice under both data-independent projections, where the optimum sits at $d=64$ (randproj, 0.178) or at the identity (publicPCA, 0.161). On the **leakage** axis, the gradient that motivated the claim ($0.944 \rightarrow 0.989$) flattens to $0.988 \rightarrow 0.989$: once the projection stops concentrating the corpus's shared variance, small d no longer compresses away what makes a note unique. And post-DP, tail-AUC sits at **0.50–0.55 for every d and every projection**: DP pins the attack at chance regardless of dimension, so the pre-DP axis was never the operative one.

The mechanism is now visible. PCA orders directions by variance *in the users' data*; at small d it keeps exactly the directions the corpus shares and discards the idiosyncratic tail. That simultaneously flatters clean retrieval and destroys the individuating signal an attacker needs — which is precisely the "both axes at once" effect. But it purchases both with the same illicit currency: information about the private corpus, spent outside the accountant. A random projection, spending nothing, buys neither.

What survives. Tiny- d remains a reasonable engineering default, on grounds that have nothing to do with a privacy/utility joint optimum: at $d=32$ the payload is **12× smaller** ($K \cdot d = 1,024$ vs 12,288 coordinates) and post-DP leakage is **identical** (0.492 vs 0.547), for 6% less private utility than the best honest setting. That is a communication/compute trade, and a favourable one — not a free lunch.

What this implies beyond this paper. Data-dependent preprocessing — PCA, whitening, vocabulary selection, learned quantisers, clip bounds read off the data (§5.2) — is both an unaccounted release *and* a confound that can manufacture a dimension effect out of nothing. It is standard practice. An identity-projection control, of the kind used above, costs one extra run and would catch it.

 Two panels: private utility vs d , and clean tail-AUC vs d , each for data-PCA, randproj, and publicPCA. The tiny- d advantage and the leakage gradient exist only under data-PCA.

Figure 2. The dimension crossover is a property of the projection, not of the mechanism. **(a)** Private utility: tiny- d wins only under the data-dependent PCA; under either data-independent projection it is the worst choice. **(b)** Pre-DP leakage: data-PCA shows the rising gradient the crossover claim rested on; the honest projections are saturated. All three converge at $d=384$, where the projection is the identity — the control. Shaded band: post-DP tail-AUC, flat at chance for every d and every projection.

7.5 The weak attack is blind exactly where you would deploy

The cosine-similarity score of §3 — rank a candidate by $\cos(x, \mu[\text{bucket}(x)])$ — is the measurement principle of the published agent-memory attacks (MEXTRA, MRMMIA) and the natural first evaluation to reach for. It is also, we now show, **actively misleading**, and in the direction that matters: it under-reports leakage precisely in the coarse- K regime a deployment would choose. We report this as a result in its own right, because it is a trap we fell into and one the surrounding literature is arranged to fall into.

The proxy certifies a leaking pool as safe. Compare the two attacks on the *identical clean release* (§7.1). At $K=32$ the cosine proxy reads **AUC 0.504** — chance, to three decimals; on this evidence the pool leaks nothing and there is no privacy problem to solve. The calibrated LiRA, on that same release, reads **AUC 0.833, TPR@1%FPR 0.175 (17× the floor), and reconstructs 77% of centroids to a true in-bucket note**. The pool was never safe. The proxy simply could not see it, because an uncalibrated cosine score compares a member's similarity against a *population* baseline, and at coarse K the population baseline is high: every candidate is close to a centroid that averages hundreds of notes. Only a *per-target* likelihood ratio — calibrated against shadow releases with and without that exact note — separates "close because the bucket is broad" from "close because I am in it."

And it manufactures a false story about *where* leakage lives. Because the proxy's sensitivity grows with K (0.504 $\rightarrow$ 0.738 as K goes 32 $\rightarrow$ 2048) while the calibrated attack is already strong at $K=32$ (0.833), a proxy-only evaluation concludes that leakage is a **sparse, high- K , low-count-tail phenomenon** — a corner case, present only in a regime whose utility retention (15–41%) nobody would ship. That is exactly the conclusion our superseded draft drew, and it is wrong twice: it understates the threat at the deployed operating point, and it invites the reader to dismiss the mechanism as solving a problem that only exists where the system is useless anyway.

What the proxy *does* establish, kept for the record. On the sparse tail it is able to see ($K \geq 512$, where 2–16% of members sit in buckets with ≤ 3 contributors), clean memory re-identifies tail members at **AUC ≈ 0.93** and DP drives that to 0.53–0.55 at $\epsilon \approx 9.3$. We state its residual precisely rather than rounding it to "chance": the 0.03–0.05 gap above 0.5 is statistically resolvable (4.4σ at $K=2048$). The calibrated attack answers what that residual is *worth*: at the same operating point LiRA reads AUC 0.504 with TPR@1%FPR on the 1% floor. So the residual is an artifact of the proxy's weakness in *both* directions — it sees a signal that buys nothing at high K , and misses one that buys plenty at low K .

This confound, like the projection, is not specific to us. §7.4 shows a data-dependent *preprocessing* step fabricating a finding; this section shows an under-powered *attack* erasing one. Both are defaults — PCA is the obvious projection, cosine similarity is the obvious membership score — and both bias the conclusion toward "the mechanism is fine." An evaluation that reports only an uncalibrated proxy has not measured privacy; it has measured its own attack. The remedy is cheap: our LiRA needs no model training (the aggregation is numpy), and 48 shadow releases run in **34 seconds** per operating point.

7.6 Realistic payload: LLM-distilled notes

The real agent-memory payload (distilled notes) **strengthens** the case. The distillation is a fresh local-LLM run (Ollama `qwen2.5:7b`; 500 users $\rightarrow$ 6,116 notes, 100-user pilot $\rightarrow$ 1,715 notes).

Utility (answer-recall@5, vector-only release), density lifts DP retention:

N (users)	K	clean	$\epsilon \approx 9.3$	retention
500	32	0.451 $\pm$ 0.020	0.402 $\pm$ 0.032	89%
500	64	0.330 $\pm$ 0.025	0.266 $\pm$ 0.046	81%
100 (pilot)	32	0.496 $\pm$ 0.029	0.324 $\pm$ 0.068	65%

At full scale (500 users, denser buckets) the distilled pool retains **89% at $\epsilon \approx 9.3$** ; the 100-user pilot retains 65%; **density, not scale per se, governs retention** (more contributors per bucket $\Rightarrow$ cheaper DP).

 Answer-recall@5 vs privacy budget for distilled notes, 500-user vs 100-user across K .

Figure 4. Distilled-notes utility (answer-recall@5). Density governs DP retention: the dense 500-user buckets ($K=32$) retain **89%** at $\epsilon \approx 9.3$, whereas the sparser 100-user pilot retains only 65% at the same budget. More contributors per bucket $\Rightarrow$ cheaper DP.

Leakage: distilled notes leak **more** than raw turns, yet DP kills both (full 500-user, $K=1024$, tail-AUC):

source	clean all-AUC	clean tail-AUC	$\epsilon \approx 9.3$ tail-AUC	above chance
raw dialogue turns	0.682	0.929	0.541 ± 0.053	0.8σ
LLM-distilled notes	0.801	0.963	0.557 ± 0.026	2.2σ

Distillation **concentrates identifying facts**, so distilled memory is *more* re-identifiable pre-DP (all-AUC $0.68 \rightarrow 0.80$, tail $0.93 \rightarrow 0.96$), but the private release still drives both to within $\sim 2\sigma$ of chance. The gap is wider than the data-PCA grid showed ($0.64 \rightarrow 0.73$), for the same reason as §7.3. The payload agents actually store is the one DP protects most decisively.

 MIA tail-AUC vs privacy budget: distilled notes above raw turns in the clear, both collapsing to chance under DP.

Figure 5. Distilled notes leak *more* than raw turns in the clear (distillation concentrates identifying facts: clean tail-AUC $0.93 \rightarrow 0.96$), yet the SecAgg+Skellam release collapses *both* to near-chance at $\epsilon \approx 9.3$. The realistic payload strengthens, not weakens, the result.

7.7 Accounting results

The total ϵ decomposes cleanly, and three of its four terms are zero or negligible ($\sigma=0.606$, $\delta=1e-5$, $K=32$, $d=32$):

term	ϵ	note
continuous-Gaussian RDP reference	9.2909	—
+ discretisation (Skellam)	9.2909	surcharge 1.3e-9 : discretisation is free at <code>range_max=1e6</code>
+ projection (public seed)	9.2909	data-independent $\Rightarrow$ +0.000
+ DP clip-bound selection ($\epsilon_c = 0.1$)	9.3109	+0.020 (0.2%)

- **Discretisation is free.** At `range_max = 1e6` the discrete Skellam ϵ equals the Gaussian-RDP ϵ to nine decimals; the integer/SecAgg quantisation costs no privacy.
- **The projection is free.** The public-seed random projection is data-independent, so it adds zero ϵ — unlike the PCA it replaces, whose cost was unbounded and unaccounted (§7.2).
- **The clip bound is nearly free in ϵ , and cheap in utility.** DP-selecting `C` with the exponential mechanism at $\epsilon_c = 0.1$ costs **0.2%** of the budget (§5.2), and `B := C` costs nothing at all. The selection is conservative — it over-estimates `C` by $\sim 1.6\times$ and therefore over-noises — which is what turns 0.416 into **0.406** at `K=32` and 0.117 into 0.100 at `K=256`. The superseded draft read `C` and `B` straight off the private data and charged neither.
- **Vector-only dominates, at a fixed occupancy rule.** At matched σ the vector-only release gives **identical recall to the last decimal** as the two-channel design, at ϵ **14.0 $\rightarrow$ 9.3**, because the count *magnitude* only ever cancelled under normalisation. One composition, $\sim 1.5\times$ tighter ϵ , same utility. The one thing the count channel did supply is **occupancy** — which buckets are non-empty — and

that does not cancel. At the `K` we recommend and report, no bucket is empty, so the rule is vacuous and the domination is unconditional; at high `K` an occupancy channel must be bought, and \$7.10 measures what it costs and how well it works.

- **Repeated release is the one term that is *not* cheap — and the one a memory pool cannot avoid.** Every entry above prices a *single* release. A deployed memory is re-aggregated as users write notes, and RDP composes additively, so `T` naive re-releases at $\sigma=0.606$ cost $\epsilon \approx 22 / 44 / 93 / 153$ for `T` = 4 / 12 / 30 / 52. This dwarfs every other term here by two orders of magnitude, and it is the term most easily left implicit. It is, however, *payable*: the required σ grows only as $\sqrt{T}$, so a cadence can be bought up front — **monthly re-aggregation for a year at 81% retention, inside the same $\epsilon \approx 9.31$ (\$5.7).** The public parameters do not recompose (`C` is selected once; the projection and anchors are public-seed), so ϵ_c is charged once regardless of `T`.

7.8 Robustness

Every number above is a **5-seed mean with the final (not peak) metric**, reported with its std. The refactor that introduced the `--proj` flag was validated by re-running `--proj pca` and checking it reproduced the previously released grid **bit-identically** (verified on the utility, leakage and distilled paths, to 1e-9); the projection is therefore the only variable in the §7.2 ablation. The subsequent switch to a DP-selected clip bound (§5.2) changes every arm identically. Re-running the full grid at 5 seeds reproduced every qualitative headline with **no sign flip** except the dimension crossover of §7.2, which reversed — the point of that section.

7.9 At-scale generality (LongMemEval `s`, 246k notes)

We repeat the utility and leakage measurements on the **full `s` variant**, the same 500 users but **246,073 notes** (~96% distractors), ~22× the oracle corpus. Both axes behave exactly as §8's density argument predicts.

Utility is free (evidence-recall@5, d=32, 5-seed):

<code>K</code>	<code>chance</code>	<code>clean</code>	$\epsilon \approx 9.3$	$\epsilon \approx 3.2$	retention@ $\epsilon \approx 9.3$
32	0.156	0.422 ± 0.056	0.421 ± 0.059	0.422 ± 0.058	100%
64	0.078	0.309 ± 0.041	0.312 ± 0.041	0.301 ± 0.037	101%
128	0.039	0.223 ± 0.023	0.218 ± 0.023	0.201 ± 0.027	98%
256	0.020	0.159 ± 0.020	0.154 ± 0.018	0.134 ± 0.022	97%

The 100–101% cells are not evidence that noise *helps*: the clean/private differences (≤ 0.003) are an order of magnitude below the 5-seed std (0.02–0.06). The honest reading is that at this density **DP costs nothing measurable**.

The vulnerable tail vanishes. At this density essentially every bucket has many contributors, so the low-count tail (≤ 3 contributors) is **empty (0% of members)** across $K \in \{512, 1024, 2048\}$, and membership

inference is **already at chance without DP** (all-AUC $\approx$ 0.51–0.53):

	K	low-count tail %	clean all-AUC	$\epsilon \approx 9.3$ all-AUC
	512	0.0%	0.508	0.508
	1024	0.0%	0.519	0.505
	2048	0.0%	0.529	0.502

This is the honest at-scale reading promised in §8: the dramatic leakage-*drop* is a sparse-tail phenomenon (§7.3), whereas the dense at-scale regime is **safe on both axes for free**: averaging over hundreds of contributors per bucket already destroys the membership signal, and DP costs no utility at all. The at-scale run therefore **confirms and bounds** the headline rather than extending it.

How to read this, corrected. The superseded draft used this run to argue that the leakage-drop is "really" a sparse-tail phenomenon and that the dense regime is safe for free. That reading was an artifact of the *proxy* (§7.5): what the `s`-variant shows is that the **proxy's tail statistic** vanishes at density, not that the pool stops leaking. The calibrated attack of §7.2 breaks dense, coarse-`K` releases (AUC 0.833 at `K=32` on the oracle corpus) where the proxy reports chance. The at-scale run therefore bounds the *proxy's* headline, and confirms the utility half — at this density DP costs nothing measurable (97–100% retention) — but it is **not** a boundary on the result.

7.10 The published attacks against a live agent (MEXTRA / MRMMIA)

The attacks so far operate on the released embeddings. To close the loop on the *published* threat model (a live LLM agent that stores and serves memory as **text**), we build an A-MEM/Mem0-style shared-memory agent (local `qwen2.5:7b`) and run both attacks end-to-end. The agent retrieves the top-`k` shared-memory notes for a query into its context and answers; the adversary issues (a) a **MEXTRA** extraction prompt that asks the agent to reproduce its memory verbatim, and (b) a **MRMMIA** membership probe for a candidate note. We hold the distilled notes fixed and swap only the shared-memory back-end:

shared memory back-end	MEXTRA verbatim-recovery	MRMMIA-AUC
raw text (baseline, no privacy)	1.000 $\pm$ 0.000	0.981 $\pm$ 0.002
our SecAgg+Skellam centroid pool ($\epsilon \approx 9.3$)	0.017 $\pm$ 0.012	0.526 $\pm$ 0.044

(60 users, 883 distilled notes, $K=256$, $d=32$, the paper's mechanism — `randproj` + DP clip; 40 extraction and 120 membership trials per seed, 3 seeds.) On the raw-text agent both published attacks succeed decisively: every targeted member note is reproduced verbatim and membership is inferred at AUC 0.98. Against our release both collapse: membership is at chance (0.526 ± 0.044 , straddling 0.5 across seeds: 0.528 / 0.471 / 0.578).

The private-column MEXTRA figure is **0.017, not 0**, and the distinction matters. The centroid pool contains no member text, so verbatim recovery is *structurally* impossible: the agent's context holds only

public notes decoded from centroids. The 1.7% is therefore the **false-positive rate of the recovery detector** — a decoded public note that happens to sit within the 0.9 embedding-similarity threshold of a target member note. It measures our measurement, not the release. We report it rather than round it to zero.

A harness bug we found and fixed. The membership probe originally drew its non-members from the same held-out set that served as the adversary's public decode corpus. In `private` mode the agent's context is that corpus, so non-member candidates appeared verbatim in the context while members never could, and the attack scored **below** chance (MRMMIA-AUC 0.31–0.35 — an inverting adversary would have read 0.65–0.69). Any AUC that lands reliably below 0.5 is a design error, not a privacy result. The corpus is now split three ways — members / non-members / public decode targets, pairwise disjoint — which is what the table above reports. The superseded draft's 0.454 carried the same confound.

(This is a demonstration at modest scale, not a tuned attack sweep; a stronger prompt-injection adversary against the raw baseline would only widen the gap, since our release exposes no text either way.)

How to read this. MEXTRA is a prompt-injection attack that induces an agent to echo its **raw-text** memory. Our release stores no text, so the correct claim is not that we *defeat* MEXTRA but that we **structurally immunise** the agent against it: the attack's target object no longer exists. Stating it otherwise would be a strawman, since any vector-only datastore inherits the same immunity for free. The adversary that a vector payload genuinely must answer to is **embedding inversion** — recovering a note from the released centroid. That is the reconstruction-decode attack of §7.8, and we run it in its *strongest closed-set form*: the adversary is handed the true candidate note set and need only pick the right element, which upper-bounds free-form inversion (e.g. `vec2text` -style decoders) on the same release. It recovers **91%** of clean centroids and **0.003** under ours. §7.8, not §7.9, is therefore the extraction result that carries weight for our mechanism; §7.9's role is to show what the *status-quo* agent leaks, and that the artifact those published attacks consume is simply gone.

7.11 Occupancy: what the count channel actually buys (§5.3)

An empty bucket is the one place the count channel is not redundant: `normalize` turns a pure-noise `S[k]` into a unit vector that competes for top- `k` slots against genuine centroids. We measure (a) how often empty buckets occur, and (b) whether they can be detected *privately*. Real LongMemEval-oracle (10,957 notes, 500 users, $d=32$), the paper's mechanism (randproj, DP clip), $\sigma_v = 0.606$ ($\epsilon \approx 9.3$); occupancy over 5 anchor seeds, detection on a single release. Reproduce with `scripts/agentmem/_occupancy_channel.py`.

(a) At the operating points, there are none.

K	32	64	128	256	512	1024	2048
empty buckets (%)	0.00	0.00	0.00	0.23 ± 0.19	2.66 ± 0.88	10.14 ± 1.53	22.91 ± 2.01

Every retrieval number in this paper is reported at $K \leq 256$, where at most **one bucket of 256** is ever empty; at the recommended $K = 32$ there are none on any seed. The noisy-normalisation failure mode is **absent from the reported utility** rather than suppressed by tuning.

(b) Where it does occur, occupancy is expensive to release. Detection AUC (empty vs occupied; 0.5 = undetectable), against the total ϵ of the release:

occupancy rule	sensitivity C_c	ϵ	K=512	K=1024	K=2048
$\ S[k]\ $ vs analytic noise floor $\sigma \cdot C \cdot \sqrt{d}$ (free: post-processing)	—	9.31	0.497	0.485	0.481
raw-count channel, $\sigma_c = 2$ (cheap second composition)	20.2	9.78	0.695	0.561	0.550
user-indicator channel, $\sigma_c = 2$	9.7–12.4	9.78	0.723	0.593	0.549
raw-count channel, $\sigma_c = \sigma_v$ (full second composition)	20.2	13.94	0.824	0.683	0.633
user-indicator channel, $\sigma_c = \sigma_v$	9.7–12.4	13.94	0.873	0.764	0.698

Three readings, all load-bearing. First, the right channel is the **binary user-indicator** (each user contributes 0/1 per bucket), not the raw count: it roughly halves the sensitivity and buys 5–9 AUC points at identical ϵ . Second, it is still **not free**, and the intuition that it should be is a note-level intuition. Under **user-level** DP, deleting a user erases every entry of its indicator vector at once, so the L2 sensitivity is $\sqrt{b_u}$ — about 5–8 here, and its DP-selected public bound lands at 9.7–12.4, not 1 — and a full second composition (ϵ 9.31 $\rightarrow$ 13.94) is what buys AUC 0.698 where it is most needed ($K = 2048$, 23% empty). Third, the free rule — thresholding the released vector's own norm against $\sigma \cdot C \cdot \sqrt{d}$, which costs no privacy because S is already public — is **at chance** (0.48–0.50) under the final mechanism: the DP-selected clip bound is deliberately conservative, and the extra noise it buys erases the norm signal entirely.

Neither is an implementation shortfall. The DP noise that drives membership inference to chance in a one-contributor bucket (§7.3) is *the same noise* that hides whether the bucket has a contributor at all: **occupancy and membership are the same signal**, and a mechanism cannot hide the member while revealing the bucket. The design consequence is to operate at dense K , where retention is highest anyway (§7.1), rather than to buy a count channel that cannot pay for itself.

8. Discussion and Limitations

The endpoint is *not* confined to the sparse tail — and believing it was is what a weak attack does to you. An earlier version of this paper conceded here that the 0.9 $\rightarrow$ 0.5 tail-AUC drop "lives in the low-count tail," that dense buckets are protected by averaging anyway, and that the result should therefore be framed narrowly as "*DP protects the vulnerable tail a sum mechanism most exposes.*" **We withdraw that concession.** It was an artifact of measuring with an uncalibrated cosine proxy, which reports chance

(0.504) at $K=32$ on a release the calibrated attack breaks at AUC 0.833 with $17\times$ -above-floor TPR and 77% note reconstruction (§7.1, §7.5). Averaging over a coarse bucket does *not* protect its members; it only defeats an attacker who compares against a population baseline instead of a per-target one. The honest frame is the stronger one: **the clean pool leaks at every fidelity we measured, and DP pins the calibrated attack at the false-positive floor at every fidelity we measured** — the privacy axis is flat in K , and the operating point is chosen on utility alone. The at-scale s -variant (§7.9) remains a genuine boundary on the *proxy's* tail statistic (with 246k notes the low-count tail is empty), but it is not, as we previously wrote, a boundary on the result.

Attack strength. We evaluate at three escalating strengths and the endpoint holds at each: (i) an embedding-similarity proxy (§7.4, §7.5), which we now report chiefly as a *cautionary* instrument rather than as evidence; (ii) a **calibrated offline-LIRA** MIA reported at low-FPR TPR plus a reconstruction-decode extraction attack (§7.2), which reveal the clean pool is *far* more leaky than the proxy showed — at the recommended $K=32$, TPR@1%FPR 0.175 and 77% reconstruction where the proxy saw nothing at all — yet still fall to the false-positive floor under DP; and (iii) the **published MEXTRA/MRMMIA attacks against a live agent** (§7.10), which fully extract a raw-text memory (recovery 1.0, AUC 0.98) but recover nothing from the centroid release. The endpoint thus **strengthens** as the attack gets stronger, which is the signature one wants: a defence that only survives weak adversaries usually fails on the first strong one, and ours does the opposite. Limits of (iii): it is a modest-scale demonstration on one open model with untuned extraction prompts; a stronger prompt-injection adversary would widen, not close, the gap, since our release exposes no text regardless.

Reconstruction and membership do not die together at coarse K . Stated plainly because it is the one place the recommended point is not fully clean: at $K=32$, DP drives *membership* to the floor (TPR@1%FPR 0.175 $\rightarrow$ 0.011) but only halves *reconstruction-decode* (0.771 $\rightarrow$ 0.396, against a ≈ 0.08 noise floor). The residual is largely a property of the metric at coarse K — a centroid there averages ~ 340 notes, so "the top-1 decode is a true in-bucket member" is partly satisfiable from bucket breadth alone, and the disclosure is region membership rather than user identification — but it is above floor, and we do not round it away. A deployment for which reconstruction is the operative threat should run at $K=128$, where decode reaches its floor (0.070) and membership stays at it, for 72% retention instead of 95% (§7.1).

Scope: the pool is a routing prior, not a note exchange. The release is K centroid vectors and **no text**, so a receiving agent cannot read another user's note out of it, and we make no such claim (§1). Utility is accordingly measured as *routing* fidelity — did the query reach the bucket holding its evidence — not end-to-end downstream QA; extending to generated-answer quality is future work, as is a text-bearing second tier, which would need its own budget. Retrieval is bucket-granular, not exact-note ranking. This is a narrower product than "every agent inherits every fix," and it is the one the mechanism can carry under a guarantee.

Deployment gaps we specify but do not measure. Four, stated plainly.

1. **Client dropout:** our runs assume full participation. A naive μ/N noise share loses the guarantee precisely when turnout falls — at 50% survival the true budget is $\epsilon \approx 13.9$, not the nominal 9.3 — so a

deployment must use the $M_{\min}$ -calibrated share or fault-tolerant noise reconstruction of §5.6. We specify both; we measure neither. (Repeated release, the sibling of this gap, we now *do* account for and measure: §5.7.)

2. **Occupancy at high K** : the leakage tables release the vector-only pool with *no* occupancy suppression, so they contain no oracle. What a dense high- K deployment needs for *retrieval* — a private occupancy gate to keep noise-only buckets out of top- k — is a real cost we do not pay here, and §7.11 prices it: no rule is simultaneously free and accurate, because occupancy and membership are the same signal. Note this cost is now easier to avoid than to pay: §7.1 shows the frontier's optimum is at coarse K anyway.
3. **δ at production scale**: $\delta=1e-5$ is $200\times$ below $1/N$ at our $N=500$ **users**, but a $1e5$ -user fleet must retighten it (§5.4), at a cost of $<23\%$ ϵ .
4. **Drift across a multi-round deployment**: §5.7 prices the *budget* of T releases but holds the corpus fixed; it does not model a fleet whose topics move between rounds, which would additionally require periodic re-seeding of the (public, zero-cost) bucket geometry. The composition result is sound as an accounting statement and untested as a longitudinal one.

On the choice of $\epsilon \approx 9.3$. It is not a tight budget by the standards of the DP literature, and we do not present it as one. Two things should be weighed against it. First, it is an **end-to-end** budget: it covers the projection, the LSH anchors, the clip bound and the quantiser bound, every one of which is public or DP-selected (§7.7). The smaller ϵ values commonly reported for pipelines of this shape typically account only for the final noise addition and silently exclude a data-dependent preprocessing step of exactly the kind §7.4 shows to be both leaky *and* distorting — so the numbers are not comparable in the direction a reader would assume. Second, the budget is a means: at this ϵ , every attack we can mount — the calibrated LiRA, the reconstruction decode, and both published attacks against a live agent — is driven to its floor.

The cost of honesty, and what it buys. Closing the two unaccounted releases — the data-fit projection (§4) and the data-read clip bound (§5.2) — lowers every clean-utility number in §7 by roughly a quarter ($K=32$ evidence-recall $0.577 \rightarrow 0.428$) and is the right trade. The ϵ of §5.4 now covers the whole pipeline; the clip selection costs 0.2% of it and $B := C$ costs nothing; the leakage-drop endpoint (§7.3) and the calibrated attack (§7.8) both get *stronger*, because the discarded PCA had been pre-anonymising the corpus for free. We report the superseded data-PCA grid alongside, as the §7.2 ablation, rather than quietly deleting it. The one casualty is the dimension crossover, an artifact of the discarded step; we treat its refutation as a result (§7.2) rather than a footnote.

We have not tried **DP-PCA** — fitting the projection under its own privacy budget — which is the only route we know of that would recover the variance concentration soundly, at the cost of a larger ϵ and a second mechanism to account for. That is the natural next step, and §7.2's ablation quantifies exactly how much utility is on the table ($0.151 \rightarrow 0.308$ in private topic-accuracy at $d=32$, if it could be had for free — which it cannot).

Stationarity and fidelity. Two structural assumptions. The bucket geometry is fixed for an aggregation epoch, so a fleet-wide topic shift can starve some buckets (noise dominates) and crowd others (the global clip bites). Because both the anchors and — once the fix above is applied — the projection derive

from a public seed or public data, the geometry can be **re-initialised periodically at zero privacy cost**, which is the natural remedy; we do not evaluate drift. Separately, $K = 32$ is a coarse memory: retrieval is bucket-granular and the pool is 32 vectors. Finer semantic resolution need not come from pushing K into the regime where buckets starve (§7.1); a two-tier pool — coarse, dense, high-retention buckets for routing, then a sub-pool consulted after routing — is the natural architecture, but the second tier needs its own privacy budget and is not free. We leave it to future work.

Non-novel components, explicitly. The dimension dependence of DP is classical [19, 20]. We had claimed a *coupled* manifestation across leakage and utility in agent memory; §7.2 retracts that claim and shows the coupling was induced by a data-dependent projection. What we now claim on this axis is the refutation and the control that exposes it. The SecAgg + Skellam path is prior work [2, 5, 6], and the LSH-bucketing-plus-DP skeleton overlaps the centralized *DP Datastore Generation* [15] (§2); the novelty is the federated/curator-free SecAgg+Skellam composition, the agent-memory payload, and the measured attack-drop endpoint.

What we would most like to be checked. Two claims carry the paper and both are cheap to falsify, which we regard as a feature. (i) That the **cosine proxy is blind at coarse K** (§7.5) — a single LiRA run at the reader's own operating point settles it, in under a minute on CPU. (ii) That the **data-dependent projection manufactures the dimension effect** (§7.4) — an identity-projection control at $d=D$, which all projections must agree on, settles that. Both are one extra run. Both, in our case, overturned a result we had already written up.

9. Conclusion

A shared LLM-agent memory pool can be made **useful and provably private at the same operating point** — a claim that only means anything if both axes are measured there, which is the discipline this paper is organised around. Aggregating per-user bucketed memory embeddings under Secure Aggregation and the Skellam mechanism yields a curator-free central-DP **routing prior**: K centroid vectors, no text, queryable by any agent in the fleet. On the joint frontier (§7.1) the coarse- K regime is usable and safe together — at $K=32$ the pool retains **95% of clean evidence-recall at $\epsilon \approx 9.3$** while a calibrated likelihood-ratio attack falls from **AUC 0.833 and a 17×-above-floor true-positive rate to the 1% false-positive floor**, and at $K=128$ (72% retention) reconstruction reaches its floor as well. The privacy axis is **flat in K** : DP defeats the calibrated attack at every fidelity we measured, so K is chosen on utility alone. Every parameter of the release is public or DP-accounted, so that ϵ is the whole cost — the discrete mechanism is privacy-free at our quantiser resolution, the public-seed projection is privacy-free by construction, the clip bound costs 0.2% of the budget, and a vector-only release dominates once occupancy is accounted for. Because a memory is re-aggregated rather than released once, we compose over the deployment: a naive cadence destroys the guarantee ($\epsilon 9.3 \rightarrow 93$ for a month of daily rounds), but a **monthly re-aggregation sustained for a year fits inside the same $\epsilon \approx 9.3$ at 81% retention** (§5.7). Reassuringly, the realistic distilled payload — which leaks *more* in the clear — is protected *more* decisively by DP.

We also report **two negative results we think travel**, both of which overturned findings we had already written up, and both of which a single control run would have caught. The dimension/density "crossover" that made tiny-`d` look like a joint privacy/utility optimum is an artifact of fitting the projection on user data — an unaccounted release that flatters the clean baseline and pre-anonymises the corpus at once; an identity-projection control catches it (§7.4). And the uncalibrated cosine proxy that agent-memory work reaches for by default is **blind at exactly the operating point one would deploy**: it reports chance (0.504) at `K=32` on a release the calibrated attack breaks at AUC 0.833, and it thereby manufactures the comfortable conclusion that leakage is a sparse-regime curiosity rather than a property of the pool you would actually ship (§7.5). The common shape is worth naming: *a default choice — the obvious projection, the obvious attack — that biases the evaluation toward "the mechanism is fine."* Across three escalating attack strengths the endpoint instead *strengthens*: the raw-text memory of a live agent is fully extractable (recovery 1.0, AUC 0.98) while our release, containing no note text at all, yields nothing.

10. Reproducibility

Active code lives in `scripts/agentmem/` (see `scripts/README.md`); the pooled crypto is `qpriviot_fl/privacy_utils.py`.

- **Utility:** `_longmemeval_probe.py` (real), `_agentmem_probe.py` (controls), `_longmemeval_distilled_utility.py` (distilled).
- **Leakage (proxy):** `_longmemeval_leakage.py`, `_agentmem_leakage.py`, `_longmemeval_distilled_analysis.py` (raw-vs-distilled).
- **Leakage (calibrated, §7.8):** `_agentmem_lira.py`, offline-LiRA MIA (AUC + low-FPR TPR) and reconstruction-decode extraction, via shadow releases.
- **Leakage (live agent, §7.9):** `_agentmem_llm_attack.py`, an A-MEM/Mem0-style shared-memory agent (local Ollama) under end-to-end MEXTRA extraction + MRMMIA membership prompts, contrasting a raw-text memory vs our centroid release. Takes `--proj/--clip-eps` like the rest; the note corpus is split three ways (members / non-members / public decode corpus, pairwise disjoint), without which the membership probe scores below chance (§7.9). Results in `experiment_results/llm_attack_rp/`.
- **Accounting:** `_skellam_accounting.py` (Skellam-RDP ϵ ; discretisation-free check).
- **Distillation:** `_longmemeval_distill.py` turns LongMemEval turns into A-MEM/Mem0-style notes via a local Ollama model (`qwen2.5:7b`); it checkpoints incrementally.
- **Projection (§4, §7.2):** every script takes `--proj {randproj,pca,publicpca}`; `randproj` is the public-seed, data-independent default (`make_projector` in `_agentmem_probe.py`, `PUBLIC_PROJ_SEED`). `--proj pca` reproduces the superseded data-dependent grid **bit-identically**, which is how the §7.2 ablation isolates the projection as the only variable.
- **Clip bound (§5.2):** every script takes `--clip-eps` (default `0.1`). `dp_quantile_clip` in `qpriviot_fl/privacy_utils.py` is the exponential mechanism over the public grid `PUBLIC_CLIP_GRID`; `skellam_rdp_epsilon(..., clip_eps=, clip_releases=)` folds its cost into the reported ϵ . `--clip-eps 0` reproduces the superseded, unaccounted empirical p95.

- **Drivers → tables/figures:** `scripts/shell/rerun_final.sh` runs the headline 5-seed grid into `experiment_results/rerun_grid_rp/*.json`, the at-scale `s`-variant into `rerun_grid_s_rp/*.json`, and the two §7.2 ablation arms into `rerun_grid_abl_pca/` and `rerun_grid_abl_pp/` (identical to the headline except for `--proj`). `scripts/shell/rerun_lira.sh` (with `--proj randproj --clip-eps 0.1`) runs the calibrated-attack grid (§7.8) into `experiment_results/lira_rp/*.json`. `rerun_figures.py -grid rerun_grid_rp` regenerates `figures/fig_*`, and the code cell at the end of this notebook regenerates every §7 table. The superseded grids (`rerun_grid`, `rerun_grid_s`, `lira`) are retained only to certify the bit-identical `--proj pca` check of §7.6. Each script has an additive `--json dump`; the crypto path is byte-identical to the released `privacy_utils`.
- **Occupancy channel (§7.10):** `_occupancy_channel.py`.

Run: `bash scripts/shell/rerun_final.sh && python scripts/agentmem/rerun_figures.py -grid rerun_grid_rp` (and `bash scripts/shell/rerun_lira.sh` for §7.8; §7.9 needs a local `ollama serve` with `qwen2.5:7b`).

- **Joint frontier (§7.1) and multi-round (§5.7):** `scripts/shell/rerun_joint.sh` fills the cells the headline grid omits — utility at $K \geq 512$, the cosine proxy at $K \leq 256$, and the *calibrated* LiRA at $K \leq 256$ — into `experiment_results/joint_rp/`, and prices the T -round schedule by injecting the solved σ via `--fl_sigma`. `scripts/agentmem/_joint_frontier.py` regenerates the frontier table, the multi-round table and `figures/fig_joint_frontier.pdf` from those JSONs (`--latex` emits the LaTeX table bodies). The LiRA-at-low- K runs are the load-bearing ones: they are what shows the cosine proxy of `_longmemeval_leakage.py` to be at chance on a release the calibrated attack breaks (§7.5).
- **Multi-round accounting:** the `releases=` argument of `skellam_rdp_epsilon(...)` in `qpriviot_fl/privacy_utils.py`; the σ column of the §5.7 table is a bisection against it (`sigma_for()` in `_joint_frontier.py`).

References

Note: the 2025–2026 agent-memory arXiv identifiers below were verified against the live arXiv/venue record (2026-07); titles and attributions match the published metadata.

[1] McMahan et al. *Communication-Efficient Learning of Deep Networks from Decentralized Data*. AISTATS 2017. [2] Bonawitz et al. *Practical Secure Aggregation for Privacy-Preserving Machine Learning*. CCS 2017. [3] Abadi et al. *Deep Learning with Differential Privacy*. CCS 2016. [4] Mironov. *Rényi Differential Privacy*. CSF 2017. [5] Agarwal, Kairouz, Liu. *The Skellam Mechanism for Differentially Private Federated Learning*. NeurIPS 2021 (arXiv:2110.04995). [6] Kairouz et al. *The Distributed Discrete Gaussian Mechanism for Federated Learning with Secure Aggregation*. ICML 2021. [7] Reimers, Gurevych. *Sentence-BERT*. EMNLP 2019 (all-MiniLM-L6-v2). [8] Wu et al. *LongMemEval: Benchmarking Chat Assistants on Long-Term Interactive Memory*. 2024. [9] Xu et al. *A-MEM: Agentic Memory for LLM Agents*. 2024. [10] Chhikara et al. *Mem0: Building Production-Ready AI Agents with Scalable Long-Term Memory*. 2024. [11] Wang et al. *Unveiling Privacy Risks in LLM Agent Memory*. ACL 2025 (arXiv:2502.13172); introduces the **MEXTRA**

memory-extraction attack. [12] Chen, Pang, Wang. *MRMMIA: Membership Inference Attacks on Memory in Chat Agents*. arXiv:2605.27825. [13] Rezazadeh et al. *Collaborative Memory: Multi-User Memory Sharing in LLM Agents with Dynamic Access Control*. arXiv:2505.18279. [14] Chen et al. *MemPrivacy: Privacy-Preserving Personalized Memory Management for Edge-Cloud Agents*. arXiv:2605.09530. [15] Abouelenein, Torki. *Differentially Private Datastore Generation for Retrieval-Augmented Inference*. arXiv:2606.01413. [16] Hou et al. *POPri: Private Federated Learning using Preference-Optimized Synthetic Data*. arXiv:2504.16438. [17] Chen et al. *Fed-SE: Federated Self-Evolution for Privacy-Constrained Multi-Environment LLM Agents*. arXiv:2512.08870. [18] Lin et al. *A Survey on Long-Term Memory Security in LLM Agents: Attacks, Defenses and Evaluation*. arXiv:2604.16548. [19] Chen, Choquette-Choo, Kairouz, Suresh. *The Fundamental Price of Secure Aggregation in Differentially Private Federated Learning*. ICML 2022 (arXiv:2203.03761). [20] Bassily, Smith, Thakurta. *Private Empirical Risk Minimization*. FOCS 2014. [21] Bun, Steinke. *Concentrated Differential Privacy: Simplifications, Extensions, and Lower Bounds*. TCC 2016. (Pure ϵ -DP $\Rightarrow (\epsilon^2/2)$ -zCDP; used to compose the clip-selection cost of §5.2.) [22] Smith. *Privacy-Preserving Statistical Estimation with Optimal Convergence Rates*. STOC 2011. (Exponential-mechanism quantile selection, §5.2.)

projection = randproj (public seed) | clip_eps = 0.1 (DP-selected C)
=> every parameter of the released mechanism is public or DP-accounted.
 ϵ -relabelling (Skellam-RDP, vector-only, range_max=1e6): $\epsilon=16 \rightarrow 22.1$ $\epsilon=8 \rightarrow 9.3$ $\epsilon=3 \rightarrow 3.2$

7.1 THE JOINT FRONTIER (oracle, d=32) – both axes at the same K

K	clean recall	$\epsilon \approx 9.3$ recall	retention	LiRA AUC (clean $\rightarrow \epsilon \approx 9.3$)	TPR@1%FPR (clean $\rightarrow \epsilon \approx 9.3$)	decode (clean $\rightarrow \epsilon \approx 9.3$)	cosine proxy AUC (clean)
32	0.771 $\rightarrow$ 0.396	0.428 $\pm$ 0.046	0.406 $\pm$ 0.054	0.833 $\rightarrow$ 0.502	0.175 $\rightarrow$ 0.011	0.504	0.667 $\rightarrow$ 0.188
64	0.320 $\pm$ 0.045	0.276 $\pm$ 0.049	0.908 $\rightarrow$ 0.505	0.357 $\rightarrow$ 0.011	0.542	0.552 $\rightarrow$ 0.011	0.667 $\rightarrow$ 0.188
128	0.167 $\pm$ 0.022	0.100 $\pm$ 0.035	0.981 $\rightarrow$ 0.503	0.750 $\rightarrow$ 0.011	0.577	0.552 $\rightarrow$ 0.011	0.667 $\rightarrow$ 0.188
256	0.152 $\pm$ 0.026	0.063 $\pm$ 0.030	0.993 $\rightarrow$ 0.505	0.874 $\rightarrow$ 0.013	0.619	0.552 $\rightarrow$ 0.011	0.667 $\rightarrow$ 0.188
512	0.135 $\pm$ 0.017	0.034 $\pm$ 0.015	0.997 $\rightarrow$ 0.504	0.945 $\rightarrow$ 0.013	0.676	0.552 $\rightarrow$ 0.011	0.667 $\rightarrow$ 0.188
1024	0.128 $\pm$ 0.013	0.019 $\pm$ 0.011	0.998 $\rightarrow$ 0.505	0.957 $\rightarrow$ 0.012	0.738	0.552 $\rightarrow$ 0.011	0.667 $\rightarrow$ 0.188

TPR@1%FPR floor = 0.010 => the attack has zero usable signal.

Privacy axis is FLAT in K (DP floors every cell) => choose K on utility alone.

The cosine proxy (last column) reports CHANCE at K=32 where LiRA reads 0.833: it is blind (\$7.5).

5.7 MULTI-ROUND: cadence bought inside a FIXED total ϵ (K=32)

T	cadence	σ needed	recall@5	retention	naive ϵ (if you just re-release at $\sigma=0.606$)
1	single shot	0.606	0.406	0.95%	9.3
4	quarterly, 1 yr	1.211	0.382	0.89%	22.1
12	monthly, 1 yr	2.098	0.349	0.81%	44.2
30	daily, 1 month	3.317	0.313	0.73%	93.3
52	weekly, 1 yr	4.367	0.283	0.66%	153.3

Every row above holds a TOTAL ϵ of ~ 9.31 – the same budget quoted throughout.

The last column is the guarantee an unaccounted deployment would silently be spending.

7.3 Utility in detail: LongMemEval oracle, evidence-recall@5

K	chance	clean	$\epsilon \approx 9.3$ (was $\epsilon=8$)	$\epsilon \approx 3.2$ (was $\epsilon=3$)	retention@ $\epsilon \approx 9.3$
32	0.156	0.428 $\pm$ 0.046	0.406 $\pm$ 0.054	0.363 $\pm$ 0.059	95%
64	0.078	0.320 $\pm$ 0.045	0.276 $\pm$ 0.049	0.217 $\pm$ 0.046	86%
128	0.039	0.233 $\pm$ 0.031	0.167 $\pm$ 0.039	0.124 $\pm$ 0.029	72%
256	0.020	0.167 $\pm$ 0.022	0.100 $\pm$ 0.035	0.057 $\pm$ 0.031	60%

d-sweep @ K=128 (retention@ $\epsilon \approx 9.3$): d=32: 72% $\rightarrow$ d=64: 77% $\rightarrow$ d=128: 73%

7.4 Projection ablation (all-MiniLM-L6-v2, N=100, K=32; leakage at K=1024)

****(a) PRIVATE utility (topic-acc @ $\epsilon \approx 9.3$) – higher is better****

d	data-PCA (leaky)	randproj (free)	publicPCA (free)
32	0.308	0.151	0.147
64	0.285	0.178	0.150
128	0.240	0.158	0.142
384	0.161	0.161	0.161

****(b) Pre-DP leakage (clean tail-AUC) and post-DP ($\epsilon \approx 9.3$) – 0.5 = no leakage****

d	data-PCA clean	randproj clean	publicPCA clean	data-PCA $\epsilon \approx 9.3$	randproj $\epsilon \approx 9.3$
32	0.944	0.988	0.975	0.522	0.499
64	0.969	0.991	0.985	0.513	0.500
128	0.985	0.992	0.991	0.540	0.545
384	0.989	0.989	0.989	0.541	0.541

(d=384 is the identity projection: all three columns must agree – the control.)

7.5 The cosine proxy: MIA tail-AUC (oracle, d=32) – the WEAK attack, for contrast

K	tail %	clean tail-AUC	$\epsilon \approx 9.3$ tail-AUC	$\epsilon \approx 3.2$ tail-AUC	$\epsilon \approx 9.3$ above chance
512	2%	0.928 ± 0.011	0.551 ± 0.057	0.543 ± 0.045	0.9σ
1024	7%	0.936 ± 0.010	0.530 ± 0.014	0.499 ± 0.028	2.2σ
2048	16%	0.915 ± 0.010	0.541 ± 0.009	0.504 ± 0.012	4.4σ

7.6a Distilled-notes utility: answer-recall@5 (vector-only release)

N (users)	K	clean	$\epsilon \approx 9.3$	retention
500	32	0.451 ± 0.020	0.402 ± 0.032	89%
500	64	0.330 ± 0.025	0.266 ± 0.046	81%
100 (pilot)	32	0.496 ± 0.029	0.324 ± 0.068	65%

7.6b Distilled-notes leakage: MIA-AUC (full 500-user, K=1024)

source	clean all-AUC	clean tail-AUC	$\epsilon \approx 9.3$ tail-AUC	above chance
raw dialogue turns	0.682	0.929	0.541 ± 0.053	0.8σ
LLM-distilled notes	0.801	0.963	0.557 ± 0.026	2.2σ

7.7 Accounting ($\sigma = 0.606$, $\delta = 1e-5$)

- Gaussian-RDP reference eps = 9.2909
- Discretisation is free Skellam eps = 9.2909 (surcharge +1.3e-09)
- DP clip-bound selection (eps_c=0.1) .. total eps = 9.3109 (+0.020, 0.2%)
- The projection is free public seed, data-independent => +0.000
- Vector-only dominates two-channel eps = 14.0 -> vector-only eps = 9.3
- Repeated release is NOT free T=12 naive re-releases = eps 44.2 (buy the cadence instead: sec 5.7)

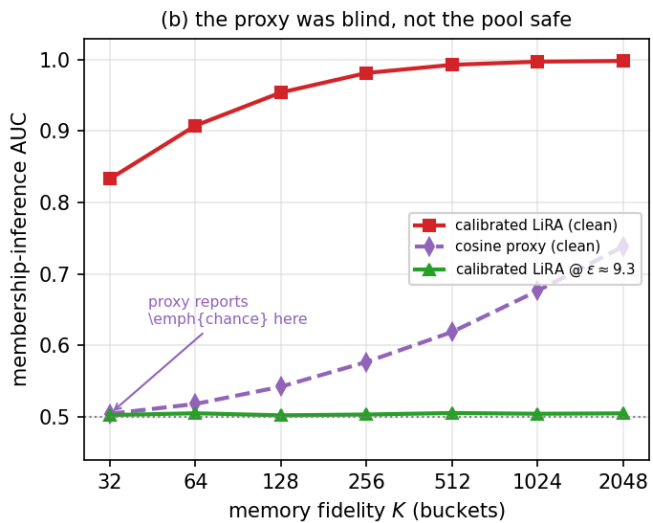
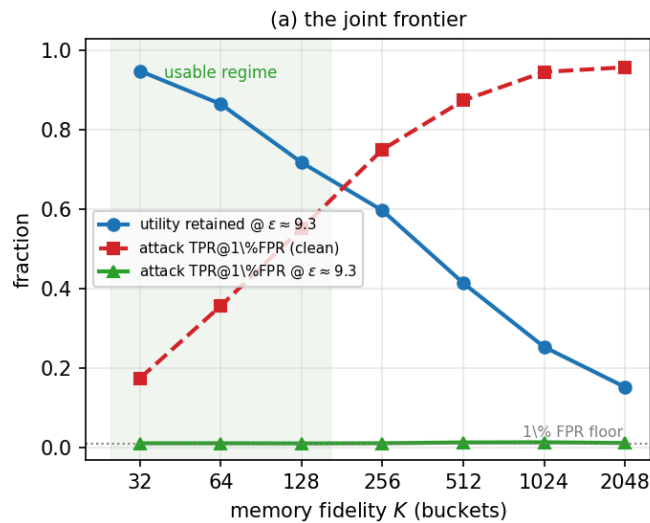
7.9a At-scale (LongMemEval s) utility: evidence-recall@5 (d=32)

K	chance	clean	$\epsilon \approx 9.3$	$\epsilon \approx 3.2$	retention@ $\epsilon \approx 9.3$	
---	---	---	---	---	---	
32	0.156	0.422 $\pm$ 0.056	0.421 $\pm$ 0.059	0.422 $\pm$ 0.058	100%	
64	0.078	0.309 $\pm$ 0.041	0.312 $\pm$ 0.041	0.301 $\pm$ 0.037	101%	
128	0.039	0.223 $\pm$ 0.023	0.218 $\pm$ 0.023	0.201 $\pm$ 0.027	98%	
256	0.020	0.159 $\pm$ 0.020	0.154 $\pm$ 0.018	0.134 $\pm$ 0.022	97%	

7.9b At-scale (LongMemEval s) leakage: the PROXY's tail vanishes (d=32)

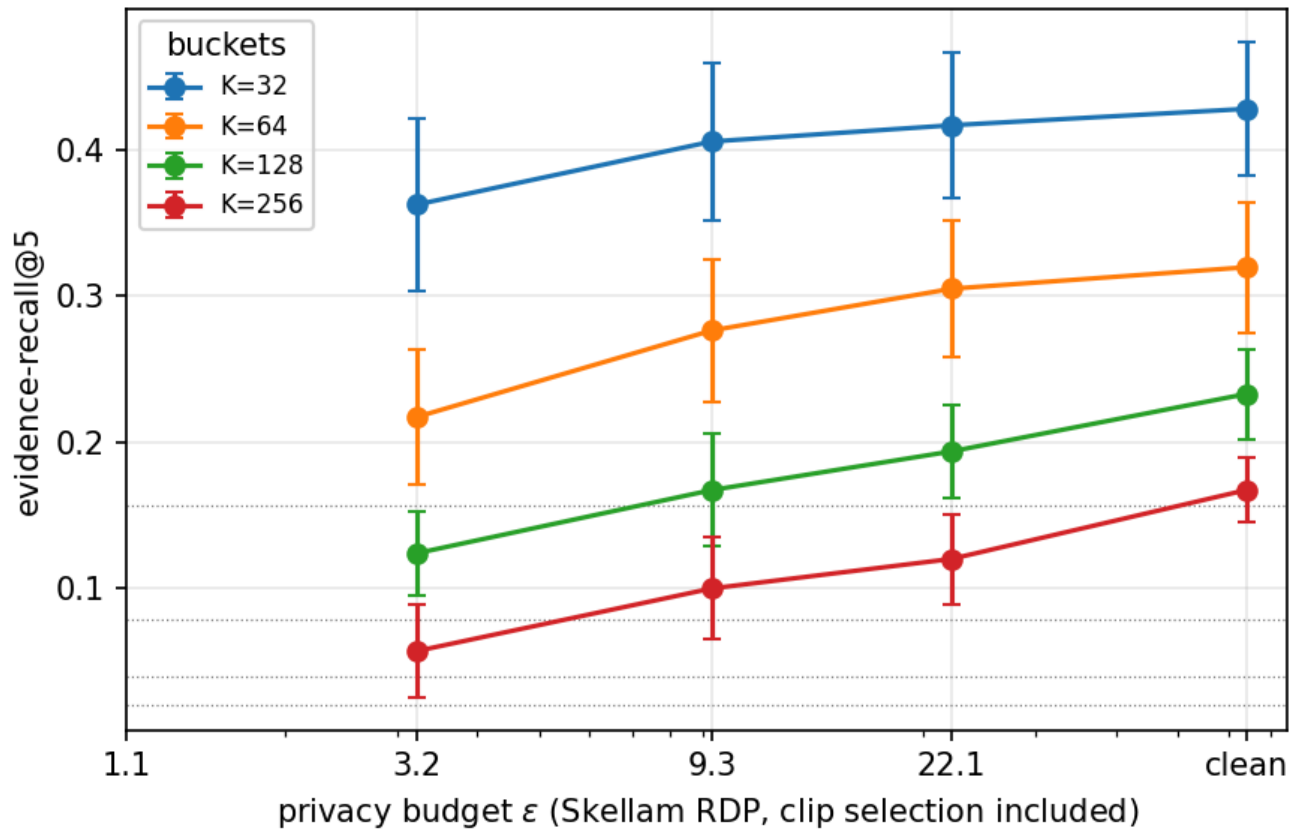
K	low-count tail %	clean all-AUC	$\epsilon \approx 9.3$ all-AUC	
---	---	---	---	
512	0.0%	0.508	0.508	
1024	0.0%	0.519	0.505	
2048	0.0%	0.529	0.502	

=== fig_joint_frontier ===



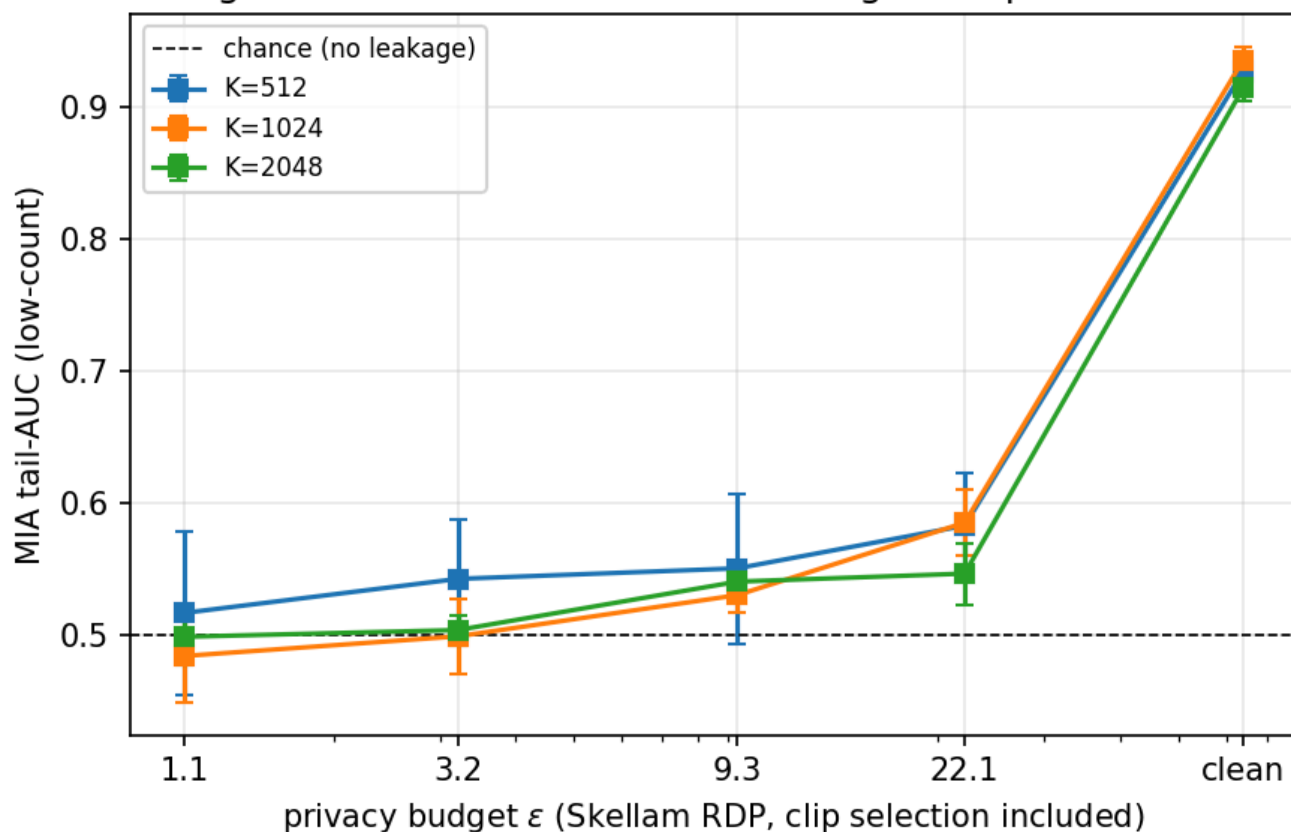
=== fig_utility_vs_eps ===

LongMemEval oracle: DP utility holds at tiny-K

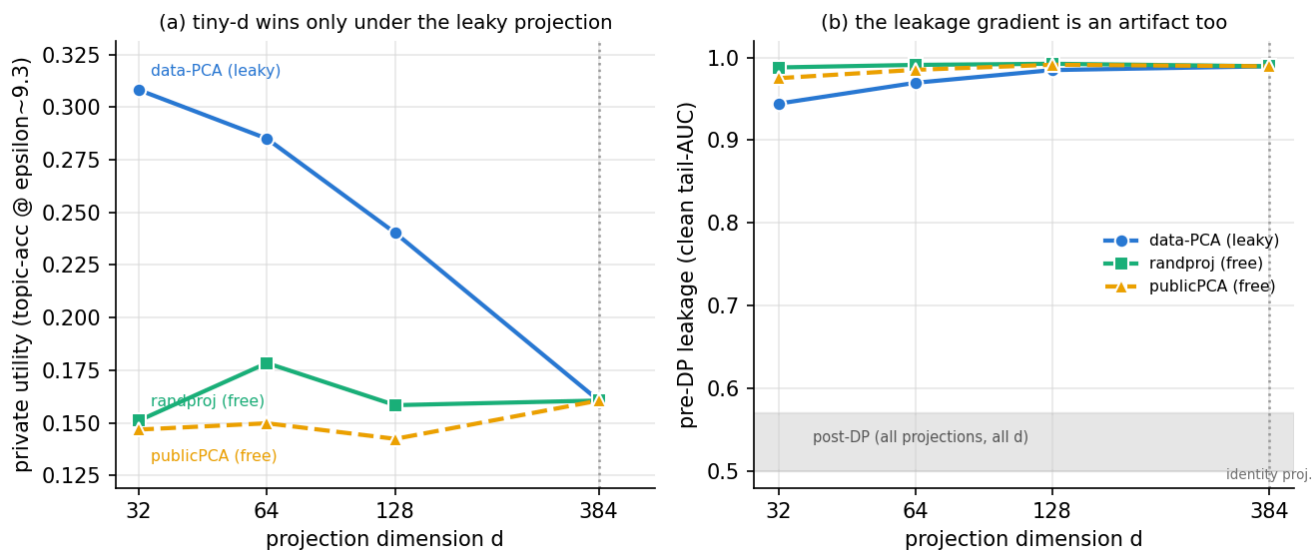


=== fig_leakage_drop ===

LongMemEval oracle: low-count leakage collapses under DP

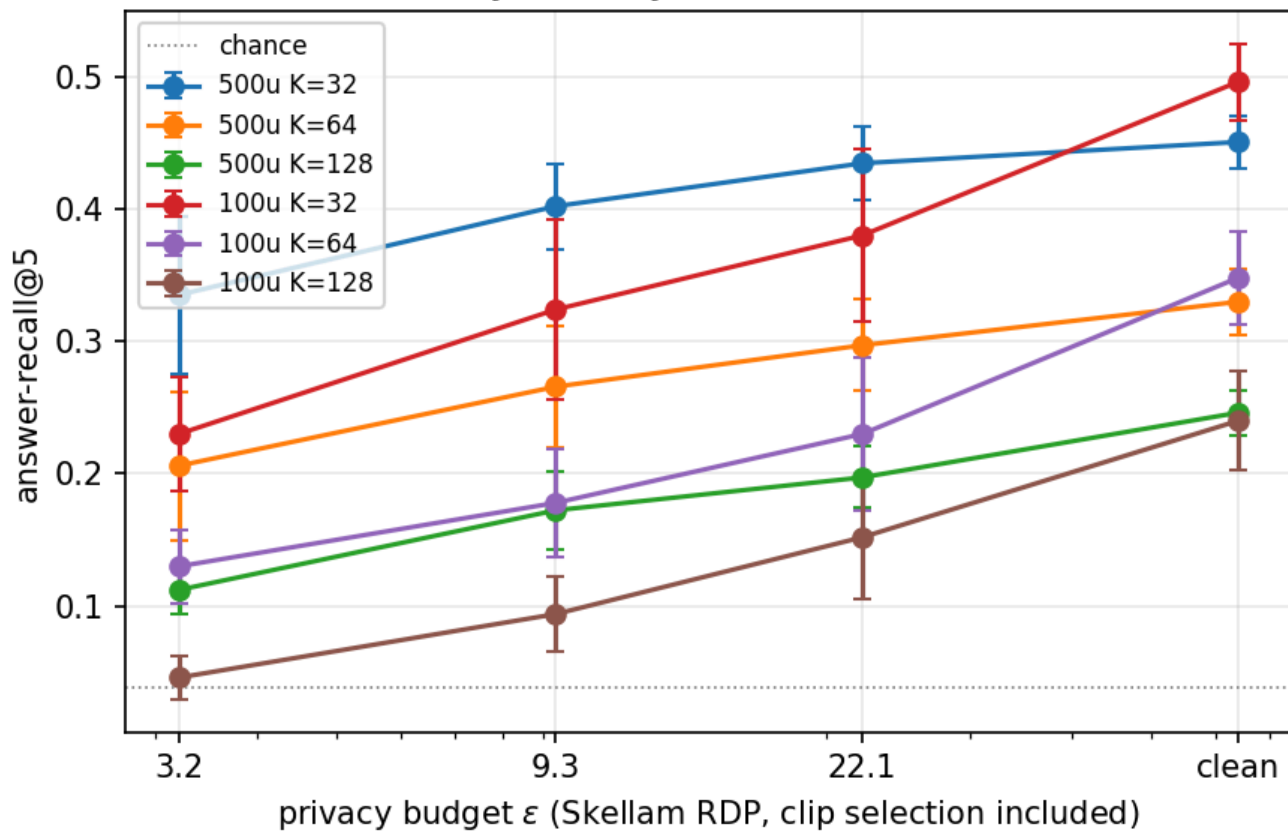


=== fig_projection_ablation ===



=== fig_distilled_utility ===

Distilled-notes utility: density lifts DP retention (500u vs 100u)



=== fig_distilled_leakage ===

Distilled notes leak MORE than raw turns, DP kills both (K=1024)

